



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

PROYECTO FINAL

SISTEMA DE GESTION DE SEGURIDAD DE LA INFORMACION (SGSI) - TECNOSYSTEM S.A.

Autores:

Girón Ramírez, José Ezequias

kgironr1@miumg.edu.gt

Quezada Gallardo, Angelo Diancarlo

aquezadag1@miumg.edu.gt

Sosa Arroyo, Danny Josue

dsosaa1@miumg.edu.gt

Rodriguez Diaz, Carlos Alejandro

crodriguez10@miumg.edu.gt

Valenzuela Tojin, Willian Eduardo

wvalenzuelat@miumg.edu.gt

NOTA 20 puntos

Profesor

Chajon Arriaza, Mario Estuardo

Curso

Principios de seguridad informática – 1er trimestre - 2026

Guatemala, Año 2026

ÍNDICE

INTRODUCCIÓN.....	ix
Objetivo general	1
Objetivos específicos.....	1
Documentación de la empresa	2
Información general de la empresa.....	2
Descripción	2
Misión, visión y valores.....	3
Valores	3
Estructura organizacional de la empresa.....	3
Servicios.....	3
Referencias de proyectos realizados.....	3
Proyecto “SysContClient CRM” (2019).....	3
Proyecto “AulaNovu Plus (2021)	4
Proyecto “PayIntegrations” (2023).....	4
Reconocimientos.....	4
Análisis de incidentes pasados.....	5
Intento de fraude financiero durante implementación de actualizaciones en ambiente del cliente.....	5
Falta de trazabilidad y registros de auditoría	6
Información sin mecanismos de respaldo	6
Uso de ingeniería social mediante suplantación de dominio corporativo.....	7
Incidentes relacionados con infraestructura física y de red	7
Inyección SQL en aplicación web	8
Compromiso de credenciales por uso de dispositivos USB no controlados.....	8
Identificación de uso de librerías vulnerables.....	8
Justificación de SGSI.....	10
Evaluación de riesgos destacando la necesidad de medidas de seguridad.....	11
Necesidad urgente de medidas de seguridad (SGSI)	12
Necesidades particulares resaltadas:	12
Objetivos de Seguridad	14

MATRIZ DE RIESGOS - TECNOSYSTEM S.A.	16
Mapa de calor de riesgos	19
Políticas de seguridad	20
Política de gestión de contraseñas	20
Política de acceso a la información.....	21
Política de protección de la información	22
Política de prevención contra malware y phishing	23
Política para desarrollo de software.....	24
Política de respaldo de la información.....	24
Política de eliminación y destrucción	24
Política de redes y accesos remotos	25
Política de capacitación y concientización en seguridad	25
Política de uso de inteligencia artificial.....	25
Procedimiento de revisión y aprobación de la política de seguridad.....	26
Revisión a nivel técnico.....	26
Aprobación de la política de seguridad.....	26
Arquitectura de seguridad.....	27
Identificación de aplicaciones críticas	27
Identificación de sistemas críticos	28
Identificación de redes críticas.....	29
PLANTILLA ESTÁNDAR DE POLÍTICA – TECNOSYSTEM S.A.....	30
MANUAL DE PROCEDIMIENTOS DE SEGURIDAD DE LA INFORMACIÓN.....	35
DOCUMENTACIÓN DE CONFIRMACIÓN DE INTEGRACIÓN DE PROCEDIMIENTOS	43
Diagrama de la arquitectura de la seguridad.....	45
Arquitectura de aplicaciones críticas	45
Arquitectura de sistemas e infraestructura.....	46
Arquitectura de redes críticas.....	47
Arquitectura de seguridad end-to-end (visión completa)	48
Hitos y cronograma de implementación	49
Revisión por expertos y aprobación.....	50

Roles participantes	50
Revisores expertos	50
Aprobador	50
Criterios de revisión.....	50
Proceso de revisión y aprobación	51
Documento de instrucciones de seguridad.....	52
Objetivos de documento de seguridad	52
POLÍTICA GLOBAL DE SEGURIDAD DE LA INFORMACIÓN - TECNOSYSTEM	
S.A.	52
Area de identidad y control de accesos.....	52
1. Gestión de contraseñas seguras	52
2. Autenticación de múltiple factor	52
Area de manejo de información confidencial	53
3. Clasificación de datos	53
4. Cifrado de información.....	53
Area de seguridad en equipos y endpoints.....	53
5. Control de dispositivos extraíbles.....	53
6. Parcheado y actualizaciones	54
Area de seguridad en el trabajo.....	54
7. VPN	54
8. Seguridad de router.....	54
Area de prevención de ingeniería social	54
9. Protocolos anti-pishing	54
10. Proteccion Vishing.....	55
Area de desarrollo seguro	55
11. Protección código fuente	55
12. Protección vulnerabilidades e inyección sql.....	55
Area de seguridad física y entorno.....	55
13. Políticas de lugar seguro y limpio	55
14. Controles de acceso	56
Area de gestión de incidentes	56

15. Reportes de anomalías	56
16. Procedimientos anti robos	56
Area de RRHH.....	56
17. Acuerdos de confidencialidad	56
18. Offboarding	57
Matriz de roles y responsabilidades.....	57
Glosario	57
1. Resumen de Revisión Técnica.....	58
2. Matriz de Conformidad	58
3. Dictamen de Seguridad.....	58
4. Firmas de Validación	58
Checklist y formularios diseñados y documentados.....	59
Implementación de un sistema para la aplicación de checklist y formularios.....	73
Objetivo del documento.....	73
Alcance del sistema	73
Funcionalidades que debe contemplar el sistema	74
Aplicación de checklist (CHECK-SEC-01).....	74
Aplicación de formularios	74
Registro y trazabilidad	74
Seguridad y control de acceso	75
Usuarios y responsabilidades.....	75
Criterios de diseño recomendados	76
Opciones de implementación.....	76
PLAN ESTRATÉGICO DEL SGSI.....	77
Revisión y aprobación por parte de la alta dirección.....	82
Acta de revisión del sgsi por la alta dirección - TECNOSYSTEM S.A.....	82
Confirmación de la alineación de los objetivos generales de la empresa	85
Objetivos generales de tecnosystem s.a.	85
Relación entre los objetivos empresariales y SGSI	86
Integración del SGSI en la estrategia organizacional	86
Establecimiento de mecanismos de revisión y actualización	87

Revisiones periódicas del SGSI.....	87
Auditorías internas	87
Revisión por la alta dirección	88
Actualización del plan estratégico del SGSI.....	88
Mejora continua	88
Plan de concientización diseñado y desarrollado por semanas/meses	89
PROGRAMA DE CONCIENTIZACIÓN EN SEGURIDAD DE LA INFORMACIÓN -	
TECNOSYSTEM S.A.	89
Estructura del programa.....	89
TRIMESTRE 1: lanzamiento y sensibilización inicial (abril - junio 2026)	89
TRIMESTRE 2: fortalecimiento y técnicas avanzadas (julio - septiembre 2026).....	91
TRIMESTRE 3: cultura de seguridad y especialización por roles (octubre - diciembre 2026)	93
TRIMESTRE 4: consolidación y mejora continua (enero - marzo 2027)	94
Listado de material de concientización que se desarrollará.....	96
Plan de evaluación periódica de la efectividad del programa	99
INDICADORES CLAVE DE DESEMPEÑO (KPIs).....	99
KPI 1: Tasa de clics en simulacros de phishing	99
KPI 2: Tasa de reporte de phishing	100
KPI 3: Cobertura de capacitación	100
KPI 4: Evaluación de conocimiento	100
KPI 5: Tiempo de respuesta ante incidentes reportados	101
KPI 6: Encuesta de percepción de cultura de seguridad	101
KPI 7: Reincidencia por usuario	101
Cronograma de evaluaciones	102
CONCLUSIONES.....	103
RECOMENDACIONES	105
REFERENCIAS BIBLIOGRÁFICAS	107

FIGURAS

Figura 1.....	2
Figura 2.....	19
Figura 3.....	45
Figura 4.....	46
Figura 5.....	47
Figura 6.....	48
Figura 7.....	49

TABLAS

Tabla 1	4
Tabla 2	11
Tabla 3	14
Tabla 4	16
Tabla 5	20
Tabla 6	20
Tabla 7	22
Tabla 8	27
Tabla 9	28
Tabla 10	29
Tabla 11	50
Tabla 12	57
Tabla 13	73
Tabla 14	75
Tabla 15	83
Tabla 16	83
Tabla 17	84
Tabla 18	84
Tabla 19	86
Tabla 20	89
Tabla 21	91
Tabla 22	93
Tabla 23	94
Tabla 24	96

INTRODUCCIÓN

El presente documento constituye el Proyecto Final del curso "Principios de Seguridad Informática" correspondiente al primer trimestre del año 2026, desarrollado por estudiantes del Programa de Posgrados de la Facultad de Ingeniería en Sistemas de Información de la Universidad Mariano Gálvez de Guatemala.

El proyecto consiste en el diseño e implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) para la empresa TecnoSystem S.A., una organización guatemalteca dedicada al desarrollo de software bajo el modelo SaaS (Software as a Service), con 35 colaboradores y operación híbrida (presencial y teletrabajo). La empresa gestiona información sensible de clientes en sectores como servicios, educación, microfinanzas y comercio, operando no solo en Centroamérica sino también con clientes en Europa y Estados Unidos.

La necesidad de implementar un SGSI en TecnoSystem S.A. surge de un análisis detallado de su historial de incidentes de seguridad, que incluye: intentos de fraude financiero durante implementaciones, falta de trazabilidad y registros de auditoría, información sin mecanismos de respaldo adecuados, exitosos ataques de phishing con una tasa de clics del 71%, manipulaciones no autorizadas en infraestructura de red, inyecciones SQL en aplicaciones web, compromiso de credenciales por dispositivos USB no controlados, y uso de librerías de terceros con vulnerabilidades conocidas.

El proyecto aborda de manera integral la protección de los activos de información de TecnoSystem S.A., desarrollando una estructura documental completa que incluye: políticas de seguridad, manual de procedimientos, instrucciones para usuarios, matrices de riesgo, formularios de reporte y solicitud, checklists de cumplimiento, y un plan estratégico alineado con los objetivos organizacionales. Todo ello fundamentado en buenas prácticas internacionales y tomando como referencia los lineamientos de la norma ISO/IEC 27001.

El trabajo ha sido desarrollado por un equipo multidisciplinario de estudiantes, bajo la asesoría del profesor Mario Estuardo Chajon Arriaza, demostrando la aplicación práctica de los principios de seguridad informática en un caso de negocio realista y relevante para el contexto guatemalteco y centroamericano.

Objetivo general

Poner en marcha un Sistema de Gestión de Seguridad de la Información que le permita a TecnoSystem S.A. dormir más tranquilos. La idea es dejar de apagar incendios y empezar a prevenir, protegiendo la información que nos confían nuestros clientes, blindando nuestros servicios SaaS y creando una cultura donde la seguridad sea parte del ADN de la empresa, no un estorbo. Queremos que nuestros clientes sigan confiando en nosotros y que podamos crecer sin miedo a que un mal día nos tire todo por la borda.

Objetivos específicos

1. Poner orden en la casa y crear una cultura de seguridad de verdad. Queremos pasar de la teoría a la práctica: definir reglas claras y sencillas que todo el mundo entienda y pueda aplicar en su día a día. Y, lo más importante, lograr que el team deje de caer en trampas de phishing. La meta es que, en un año, menos del 10% del personal haga clic en esos correos raros, en lugar del 71% actual. Se trata de cuidarnos entre todos.
2. Que el código que escribimos sea seguro desde el vamos. Basta de que nos hackeen por una validación mal hecha o por usar una librería vieja. Queremos que nuestros desarrolladores tengan las herramientas y la tranquilidad de saber que lo que están creando es sólido. Si aparece un hueco de seguridad crítico, como una inyección SQL, queremos poder parchearlo en máximo 15 días, sin drama y sin que el cliente se entere por un susto.
3. Poder dormir sabiendo que si algo pasa, lo podemos arreglar. Necesitamos tener un registro claro de qué pasó, quién lo hizo y cuándo, para no quedar como idiotas cuando un cliente pregunta o cuando algo falla. Y más importante aún: queremos estar seguros de que si borramos algo por error (o alguien lo hace a propósito), podamos recuperarlo ya.
4. Cuidar la oficina, la red y las compus de todos, estén donde estén. Desde que alguien enchufa un USB cualquiera hasta que un "curioso" mete mano en los equipos de red, queremos ponerle reglas claras. Se trata de que, si alguien trabaja desde su casa o desde la oficina, la información esté igual de segura. Cero sustos con dispositivos no autorizados y cero manipulaciones raras en el server.

Sistema de gestión de seguridad de la información (SGSI) – Empresa de tecnología, TecnoSystem S.A

Documentación de la empresa

Información general de la empresa

Nombre: TecnoSystem S.A.

Figura 1

Logotipo



Actividad económica o giro del negocio: TecnoSystem S.A. Es una empresa de tecnología dedicada al desarrollo de software, se especializa en software tipo SaaS (Software as a Service). La empresa ofrece servicios como software, almacenamiento de datos y el diseño de productos innovadores.

Ubicación: Zona 10, Guatemala, Guatemala.

Tamaño: 35 Colaboradores, con operación híbrida (Oficina + teletrabajo).

Clientes: La organización tiene clientes clasificados como PYMES y medianas empresas, generalmente ubicadas en Centroamérica, sin embargo, se han tenido contratos con clientes en Europa y Estados Unidos. Las actividades comerciales de las empresas se encuentran generalmente entre servicios, educación, microfinanzas y comercio.

Fundación: TecnoSystem S.A. fue fundada el 3 de septiembre del 2018.

Descripción

TecnoSystem S.A. es una empresa de tecnología enfocada en soluciones y productos de software confiables, estables y escalables, estos servicios resuelven las necesidades de los usuarios de mejorar sus procesos y obtener la información necesarias para tomar decisiones basadas en la mayor cantidad de datos disponibles, y permitir que el cliente optimice sus procesos y aumente sus beneficios.

Misión, visión y valores

Misión: Desarrollar soluciones seguras y prácticas que mejoren los procesos, protegiendo la información y garantizando la continuidad del servicio.

Visión: Ser una empresa referente en calidad, innovación y seguridad de los productos tecnológicos.

Valores

- a. Confidencialidad y ética.
- b. Calidad y mejora continua.
- c. Innovación responsable.
- d. Servicio.

Estructura organizacional de la empresa

- a. Gerente general
- b. Gerente de operaciones
- c. DevOps/Infraestructura
- d. Equipo de desarrollo
- e. QA/Testing
- f. UX/UI
- g. Soporte

Servicios

- a. Desarrollo y mantenimiento de plataformas web y móviles.
- b. Implementación de servicios a los clientes.
- c. Integración con sistemas externos. (facturación, pasarelas de pago, mensajería)
- d. Soporte técnico.
- e. Análisis de datos, reportaría.

Referencias de proyectos realizados.

Proyecto “SysContClient CRM” (2019)

Sistema de gestión de clientes, que incluye control de usuarios, seguimiento de oportunidades y reportes operativos, esto ayudo al cliente reducir los tiempos de atención y centralizar la información comercial.

Proyecto “AulaNovu Plus (2021)

Plataforma educativa para capacitaciones, utiliza microcursos, evaluaciones y reporte de avances, con esto se logró un mejor seguimiento del aprendizaje y estandarizar los contenidos.

Proyecto “PayIntegrations” (2023)

Este proyecto se trata de un módulo de integración con pasarelas de pagos y notificaciones automáticas (correo/SMS), con esto mejoro el flujo de cobros y reducción de procesos manuales, esto represento una mejora en control de estas transacciones.

Reconocimientos

- a. Reconocimiento interno de satisfacción del cliente. **2024.**
- b. Mención en evento local, evento de innovación “**I-nova**” **2025.**

Tabla 1

Inventario de documentos organizacionales

En esta tabla podrá encontrar los documentos organizacionales más importantes de la empresa TecnoSystem S.A. la descripción de contenidos y la frecuencia de revisiones.

Código	Documento	Contenido	Responsable	Frecuencia de revisión
DOC-01	Perfil de la empresa	Descripción, misión/visión, estructura, servicios	CEO/Gerente Op	Semestral
DOC-02	Mapa de procesos	Procesos, roles, entradas/salidas	Gerente Op	Trimestral
DOC-03	Inventario de activos críticos	Activos + dueño + criticidad	Responsable SGSI	Trimestral
DOC-04	Lista de sistemas y herramientas	Repos, nube, CRM	DevOps	Mensual
DOC-05	Matriz de roles y accesos (alto nivel)	Roles vs accesos permitidos	Gerente Op	Mensual
DOC-06	Proveedores tecnológicos	Servicios externos y responsables	Gerente Op /Compras	Trimestral

DOC-07	Respaldo y recuperación (alto nivel)	Qué se respalda, periodicidad, retención	DevOps	Trimestral
--------	--------------------------------------	--	--------	------------

Análisis de incidentes pasados

En esta sección se presenta una recopilación con los incidentes más significativos que han comprometido la seguridad en la organización durante sus operaciones:

Intento de fraude financiero durante implementación de actualizaciones en ambiente del cliente

A inicios de octubre de 2022, un grupo de implementadores se encontraba realizando el despliegue de una nueva versión del sistema de monitoreo de transacciones en el ambiente productivo de uno de los clientes, durante esta ventana de actualización se presentaron fallas en la aplicación del paquete y esto ocasionó un comportamiento irregular en el sistema. A su vez se detectó un intento de fraude financiero con el objetivo de sacar provecho durante este periodo donde el sistema se presentaba vulnerable, lo que supone que los atacantes estaban informados del proceso que se estaba realizando posiblemente por una filtración del personal interno.

A pesar de las fallas iniciales, algunos módulos del sistema permanecieron activos y mediante las reglas de detección se logró identificar patrones anómalos en las transacciones, permitiendo mitigar el intento de fraude. El informe del caso fue presentado al cliente y pasó a ser un precedente positivo ya que sirvió para reforzar la confianza del cliente en la solución adquirida.

Las consecuencias en caso de materializarse este intento de fraude hubieran sido significativas para la empresa y el cliente, ya que implicarían pérdidas económicas, procesos legales y regulatorios, penalizaciones contractuales por incumplimiento en los niveles de servicio establecidos, además de exponer a la organización con el resto de los clientes asociados por impacto reputacional.

Se deben mejorar las prácticas en los procesos de implementación y todos aquellos que estén relacionados con información de carácter sensible, así como también reforzar la confidencialidad en la gestión de estos procesos desde su planificación hasta su ejecución para no exponer información a personas no autorizadas.

Falta de trazabilidad y registros de auditoría

En 2023 el equipo de soporte reportó que no se contaba con un registro histórico eficiente, ni una centralización de logs que permitiera rastrear con detalle las acciones ejecutadas por los usuarios en las aplicaciones desarrolladas, y parte del trabajo del equipo además de dar soporte por fallas internas en las aplicaciones, también es dar un seguimiento a requerimientos de los clientes, sobre todo del sector financiero, que han llegado a hacer consultas pidiendo detalle sobre información alterada o removida y no se ha contado con una trazabilidad completa y precisa de las acciones realizadas, limitando la capacidad de análisis y evidenciando una debilidad significativa para auditoría.

Es indispensable contar con un registro de eventos que garantice la trazabilidad sobre las acciones realizadas dentro de los sistemas que la empresa provee, para dar un mejor soporte a los clientes sobre los incidentes que se puedan presentar.

Información sin mecanismos de respaldo

En diciembre de 2023, se recibió como solicitud de un cliente para una funcionalidad de migración de usuarios, que se realizara una restricción de acciones para ciertos roles, ya que en este proceso un usuario podía agregar los datos como nuevos, o bien modificar y reemplazar los existentes, estas acciones a pesar de ser necesarias para el requerimiento del desarrollo se identificaron como una amenaza para la integridad de la información, por lo que se tomó en cuenta la iniciativa de realizar una matriz de seguridad para la asignación de permisos dentro de los módulos, y en cuanto a las interrogantes de si se contaba con trazabilidad y mecanismos de respaldo adecuados, el análisis determinó que los recursos existentes no eran suficientes en su totalidad, ya que el registro de acciones no permitía reconstruir a detalle las acciones realizadas por el usuario, y la información no podía ser recuperada de forma inmediata.

En un escenario de mayor impacto este tipo de incidentes podría derivar en pérdida de información crítica o sensible, por lo que deben establecerse políticas claras de respaldo y estándares para el área de desarrollo que garanticen controles y un seguimiento estricto sobre los privilegios en el manejo de información.

Uso de ingeniería social mediante suplantación de dominio corporativo

El 13 de febrero de 2024, un colaborador reportó comportamientos anómalos en su equipo de cómputo, tras hacer una evaluación se determinó que la causa fue por haber accedido a un enlace recibido en un correo electrónico aparentemente enviado desde una cuenta relacionada a la empresa, sin embargo, tanto la dirección de correo, como el enlace utilizaban nombres de dominio similares con pequeñas variaciones en algunos caracteres.

Tras el análisis se determinó que correspondía a un sitio falso creado con el objetivo de suplantar la identidad de la organización, y que la acción realizada ejecutó código malicioso que comprometió credenciales del usuario y algunos repositorios importantes. El incidente fue contenido aislando el equipo y revocando los accesos.

Este caso representa un riesgo que podría llegar a comprometer equipos corporativos, la red de la empresa, y fuga de información sensible. Posteriormente a este hecho, se realizaron pruebas simulando casos de phishing con el personal interno de la empresa, generando envío de correos electrónicos que ofrecían supuestos beneficios, como descuentos comerciales, cupones de canje para almuerzos, y otras promociones similares.

El objetivo de estas pruebas fue evaluar el nivel de concienciación del personal frente a este tipo de amenazas, y obtener indicadores de la cantidad de colaboradores que accedían al enlace incluido en el correo, y cuantos contestaban formularios diseñados para simular la extracción de datos sensibles en algunos casos seleccionados.

Como resultado de las pruebas se determinó que aproximadamente el 71% del personal accedió al enlace, evidenciando una tasa alta de exposición frente a este tipo de ataques, siendo este un riesgo que pone en peligro la seguridad de la empresa y evidencia la necesidad de fortalecer los programas de capacitación en ciberseguridad.

Incidentes relacionados con infraestructura física y de red

Durante el primer semestre de 2025, se registraron 17 interrupciones en los servicios internos debido a fallas en la red, el análisis técnico determinó que la mayoría de las causas fueron debido a manipulaciones no autorizadas en los equipos de red de la empresa. El área no contaba con los controles adecuados, ni registros de ingresos, lo que dificultaba identificar con exactitud el origen de los eventos.

Como medidas de acción se le dio más prioridad a la seguridad física, implementando controles de accesos y monitoreo, también se definieron los procesos que solo personal con la autorización correspondiente podría realizar.

Inyección SQL en aplicación web

El 24 de abril de 2025, como parte de las actividades de monitoreo y revisión de seguridad, se detectó un acceso no autorizado a una base de datos que contenía información sensible, originada a través de una inyección SQL en un sitio público de la empresa donde las entradas de usuario no contaban con una correcta validación.

El análisis confirmó que no se afectó la integridad de la información, y la información guardada contaba con mecanismos de seguridad que mantenía la información cifrada, sin embargo, el control de acceso fue evadido por las prácticas de intrusión aplicadas por los atacantes.

Deben implementarse buenas prácticas y políticas que garanticen la protección de la información de la empresa en todo el ciclo de desarrollo, y realizar un monitoreo constante para detectar la detección temprana de este tipo de incidentes.

Compromiso de credenciales por uso de dispositivos USB no controlados

El 17 de junio de 2025, un colaborador reportó fallas en su equipo de trabajo, la causa fue haber realizado una conexión de un dispositivo USB desconocido en el computador el cual estaba infectado, al no contar con restricciones en los puertos USB esto permitió la ejecución del malware que contenía.

Fueron comprometidas credenciales del usuario, sus cuentas corporativas y la información de importancia que el equipo contenía, para lo cual, se aisló el equipo y se revocaron los accesos correspondientes.

Este tipo de incidentes es una amenaza significativa para la protección y confidencialidad de la información por lo que es necesario implementar controles y políticas claras con respecto a dispositivos extraíbles y su uso en equipos de trabajo.

Identificación de uso de librerías vulnerables

Durante el año 2025 se tuvo conocimiento de incidentes de seguridad que afectaron a organizaciones del medio tecnológico, los cuales estuvieron relacionados con la explotación de vulnerabilidades en librerías de terceros utilizadas en sus desarrollos. A raíz

de estos casos, se realizó una revisión interna de dependencias utilizadas en los proyectos, identificando que en algunos desarrollos se estaban empleando versiones coincidentes con las reportadas públicamente como vulnerables.

Se tomaron acciones preventivas que implicaron actualizar las librerías de terceros a versiones donde estas vulnerabilidades habían sido corregidas, así como también algunos casos donde se detectó que las librerías no estaban siendo utilizadas, ya que se habían instalado en conjunto con alguna otra, por lo que se removieron del aplicativo. Este incidente representa un riesgo de explotación remota de las aplicaciones desarrolladas por la organización, accesos no autorizados y afectación a los servicios prestados a los clientes.

Es necesario implementar un proceso continuo de control de dependencias, que permita evaluar y mitigar posibles vulnerabilidades antes de su explotación.

Justificación de SGSI

Llevar a cabo la implementación del Sistema de gestión de seguridad de la Información (SGSI) en TecnoSystem S.A. se justifica por la naturaleza de las operaciones que ejecuta la empresa y el tipo de información de la que hace gestión en el desarrollo y prestación de servicios de software. Al ser de una organización dedicada a dar soluciones tecnológicas bajo el modelo SaaS, la confidencialidad, disponibilidad y la integridad de la información muestran un factor crítico para la continuidad del negocio y la confianza de clientes

Por su operación, la empresa ha estado expuesta a diversos riesgos e incidentes de seguridad, como intentos de fraude financiero, vulnerabilidades en aplicaciones web, uso de librerías de terceros con fallas en su seguridad, modificaciones de información sin un respaldo correcto y compromiso de credenciales por prácticas inseguras, por lo que se evidencia la necesidad de contar con un enfoque estructurado que permita reconocer, evaluar y dar soluciones a los distintos riesgos de seguridad de la información de manera preventiva y consistente de estos eventos.

De mismo modo, la operación de forma híbrida de TecnoSystem S.A. la cual une el trabajo presencial y el teletrabajo, junto con la integración de servicios externos como pasarelas de pago y sistemas de facturación, logra que incremente la superficie de exposición a amenazas internas y externas. Ya que, sin un marco de gestión, estos riesgos pueden resultar en pérdidas económicas, afectación a la reputación corporativa, incumplimiento de contratos y disminución de la competitividad en el mercado.

Considerando lo anterior, adoptar un modelo SGSI permitirá a la organización implementar políticas, procesos y controles enfocados a proteger sus activos de información, reforzar la gestión de incidentes, mejorar la trazabilidad de las operaciones y no menos importante, promover una cultura organizacional enfocada en la seguridad. Como consecuencia el SGSI no solo contribuiría a la protección de la información, al contrario, lograría que cumplir objetivos estratégicos de la empresa y garantizar la sostenibilidad de sus servicios en un entorno tecnológico cada vez más exigente.

Evaluación de riesgos destacando la necesidad de medidas de seguridad

Tomando en cuenta la documentación y el historial de incidentes suministrados, se lleva a cabo la evaluación de riesgos para TecnoSystem S.A., haciendo un análisis en el riesgo crítico de exposición que tiene la compañía y en lo urgente que es establecer un Sistema de Gestión de Seguridad de la Información (SGSI) sólido.

Tabla 2

Categoría de Riesgo	Descripción y Evidencia (Base en Incidentes/Documentación)	Probabilidad	Impacto Potencial	Nivel de Riesgo
Amenazas Internas y Gestión de Accesos	Evidencia: Incidente 2.1 (Intento de fraude) sugiere posible filtración interna. Documentación: Existe una Matriz de roles (DOC-05), pero su revisión mensual puede ser insuficiente sin controles sólidos de segregación de funciones y monitoreo. Operación híbrida amplía la superficie de riesgo.	Alta	Crítico	ALTO
Ingeniería Social y Concienciación	Evidencia: Incidente 2.4 (Phishing) muestra que el 71% del personal hizo clic en enlaces maliciosos durante pruebas simuladas. La suplantación de dominio ya ocurrió, comprometiendo credenciales y repositorios.	Muy Alta	Alto	MUY ALTO
Vulnerabilidades en el Ciclo de Desarrollo	Evidencia: Incidentes 2.6 (Inyección SQL) y 2.8 (Bibliotecas vulnerables). La empresa desarrolla software SaaS, por lo que los defectos de seguridad se transmiten directamente al cliente. Falta un proceso continuo de evaluación de dependencias y pruebas de seguridad.	Alta	Crítico	ALTO
Falta de Trazabilidad y Respuesta a Incidentes	Evidencia: Incidentes 2.2 (Falta de trazabilidad) y 2.3 (Alteraciones sin respaldo). Sin registros de auditoría robustos,	Media	Alto	ALTO

	es imposible investigar incidentes, atribuir acciones o cumplir con posibles requerimientos legales.			
Gestión de Terceros Cadena de Suministro	Evidencia: Integración con pasarelas de pago y facturación (Servicios). Documentación: Lista de proveedores (DOC-06) existe, pero no se evidencia evaluación de su seguridad. El incidente 2.8 surge de dependencias de terceros. Evidencia: Incidente 2.3 (Alteraciones sin respaldo). Documentación: Existe un	Media	Alto	ALTO
Continuidad del Negocio y Respaldos	documento de alto nivel sobre respaldos (DOC-07), pero el incidente sugiere que los procedimientos operativos o su verificación son deficientes.	Media	Crítico	ALTO

Necesidad urgente de medidas de seguridad (SGSI)

La evaluación previa evidencia que TecnoSystem S.A. opera en un ambiente de riesgo alto y muy alto en varios ámbitos. El SGSI no solamente se justifica de manera preventiva, es como una respuesta a fallos que han ocurrido. Las medidas de seguridad, para ser eficientes y sostenibles, necesitan un marco sistemático SGSI, no pueden ser implementadas de manera aislada.

Necesidades particulares resaltadas:

1. Gobernanza y política de seguridad: Especificar oficialmente las normas de conducta que se consideran aceptables, así como la clasificación de información, las políticas de acceso y los deberes. La ética y la confidencialidad deben ser evidentes en controles particulares.
2. Gestión de accesos y activos: El sistema de gestión de identidades y accesos (IAM) debe basarse en el inventario de activos críticos (DOC-03) y la matriz de roles (DOC-05), que deben incluir revisiones de privilegios y el principio del mínimo

privilegio, el cual es especialmente importante tras un incidente que pudo ser una filtración interna.

3. Protección en términos ambientales y físicos: Aunque el incidente 2.5 indica lo contrario, la operación híbrida requiere políticas para asegurar los dispositivos en teletrabajo, gestionar los puertos USB relacionados con el incidente 2.7 y resguardar la infraestructura.
4. Seguridad en operaciones: Es el centro de la necesidad. Es necesario:
 - a. Procedimientos documentados para la administración de copias de seguridad y su restauración comprobada.
 - b. Bitácoras de auditoría centralizadas y aseguradas para todas las actividades cruciales.
 - c. Un procedimiento formal de administración de incidentes, que se nutre de las experiencias anteriores.
 - d. Controles técnicos contra el malware, que complementan la formación.
5. Seguridad en el desarrollo: Incorporar valoraciones de seguridad SAST, SCA en el ciclo de vida del desarrollo para erradicar inyecciones SQL y manejar de manera automática las bibliotecas que sean vulnerables.
6. Manejo de relaciones con terceros: Incluir en los contratos cláusulas de seguridad y evaluar la posición de seguridad de proveedores críticos, como las pasarelas de pago y la nube a través de certificados o cuestionarios.
7. Conciencia y formación: El hecho de que el 71% de las pruebas de phishing hayan resultado positivas es una señal crítica. Un programa ininterrumpido obligatorio y cuantificable es necesario para cambiar la cultura organizacional. Es la defensa principal contra el riesgo muy alto que se ha identificado.

Objetivos de Seguridad

Tabla 3

Prioridad	Objetivo Estratégico	Meta Medible
Crítica	Fortalecer la defensa contra Ingeniería Social	Reducir la tasa de clics en correos de phishing del 71% a menos del 10% en un año.
Crítica	Garantizar la integridad de aplicaciones Web	Remediar el 100% de vulnerabilidades críticas (como Inyección SQL) en máximo 15 días.
Alta	Asegurar el Ciclo de Vida de Desarrollo	Implementar análisis de seguridad en el 100% de los proyectos activos.
Alta	Optimizar la Trazabilidad Operativa	Centralizar el 100% de los logs de acciones críticas en una plataforma de auditoría segura.
Alta	Asegurar la Disponibilidad de Información	Ejecutar pruebas de restauración trimestrales con una tasa de éxito del 100%.
Media	Controlar Periféricos y Endpoints	Bloquear el 100% de los puertos USB no autorizados en equipos corporativos.
Media	Proteger la Propiedad Intelectual	Mantener en 0% la fuga de código fuente o diseños mediante el control de acceso estricto.
Media	Resguardar la Infraestructura Física	Reducir a 0 los incidentes de manipulación no autorizada de equipos de red.
Media	Resguardar la Infraestructura Física	Asegurar que el 100% de proveedores críticos cumplan con estándares de seguridad anuales.

Para alcanzar estos objetivos, la organización se debe comprometer a cumplir con los siguientes hitos durante el primer año de implementación del SGSI:

- Trimestre 1: Lanzamiento del programa obligatorio de concienciación en ciberseguridad.
- Trimestre 2: Implementación de herramientas de monitoreo de logs y automatización de seguridad en el flujo de desarrollo (CI/CD).
- Trimestre 3: Formalización de la política de seguridad física y control de dispositivos extraíbles en ambientes híbridos.
- Trimestre 4: Auditoría interna del SGSI para verificar el cumplimiento de los indicadores y ajuste de los controles de riesgos remanentes.

MATRIZ DE RIESGOS - TECNOSYSTEM S.A.

Evaluación basada en incidentes reales y contexto operativo

Tabla 4

Categoría ID de Riesgo	Descripción del Riesgo	Probabilidad (1-5)	Impacto (1-5)	Nivel de Riesgo (PxI)	Prioridad	Controles Actuales	Controles Propuestos
R- 01	Ingeniería Social Colaboradores caen en campañas de phishing, comprometiendo credenciales y permitiendo acceso no autorizado a sistemas. Evidencia: 71% de clics en pruebas internas. Vulnerabilidades en código (inyección SQL, librerías obsoletas) explotadas por atacantes, comprometiendo datos de clientes.	5 (Muy Alta)	4 (Alto)	20 (CRÍTICO)	1	Correos esporádicos de concientización.	Programa obligatorio de formación trimestral, simulacros de phishing mensuales, MFA para todos los accesos.
R- 02	Seguridad en Desarrollo Evidencia: Incidentes 2.6 y 2.8.	4 (Alta)	5 (Crítico)	20 (CRÍTICO)	1	Revisiones de código manuales esporádicas.	Implementar análisis SAST/SCA en CI/CD, política de actualización de dependencias, pruebas de penetración anuales.

R- 03	Amenazas Internas	Filtración de información por parte de personal con acceso privilegiado o durante procesos críticos. Evidencia: Incidente 2.1 (posible filtración). Imposibilidad de auditar acciones por falta de logs centralizados, afectando investigaciones y cumplimiento.	3 (Media)	5 (Crítico)	15 (ALTO)	Matriz de roles básica, revisiones mensuales.	Principio de mínimo privilegio, revisión trimestral de accesos, monitoreo de acciones de usuarios privilegiados, firma de acuerdos de confidencialidad.
R- 04	Falta de Trazabilidad	Incidentes 2.2 y 2.3. Incapacidad de recuperar datos modificados o eliminados por falta de respaldos efectivos.	4 (Alta)	4 (Alto)	16 (ALTO)	Logs locales sin retención definida.	Centralización de logs en SIEM, retención mínima de 1 año, aseguramiento de integridad de bitácoras.
R- 05	Pérdida de Información	Evidencia: Incidente 2.3. Proveedores o librerías externas vulnerables	3 (Media)	5 (Crítico)	15 (ALTO)	Respaldo básico sin pruebas de restauración.	Política formal de backups, pruebas de restauración trimestrales, backups offsite. Evaluación anual de proveedores críticos, cláusulas de
R- 06	Riesgo de Terceros		3 (Media)	4 (Alto)	12 (ALTO)	Lista de proveedores sin	

		comprometen la seguridad de la empresa o sus clientes. Evidencia: Incidente 2.8. Manipulación no autorizada de equipos de red o accesos físicos sin control.				evaluación de seguridad.	seguridad en contratos, análisis continuo de dependencias.
R- 07	Seguridad Física	Evidencia: Incidente 2.5. Infección por dispositivos USB no controlados que comprometen equipos y credenciales.	3 (Media)	3 (Medio)	9 (MEDIO)	4 Acceso físico sin registro.	Control de acceso con tarjeta, bitácora de ingresos, cámaras en sala de servidores, política de puertos USB bloqueados.
R- 08	Malware por Dispositivos	Evidencia: Incidente 2.7.	3 (Media)	3 (Medio)	9 (MEDIO)	4 Sin restricción de puertos USB.	Bloqueo GPO de puertos USB, estaciones de escaneo de dispositivos, política de uso de medios extraíbles.

Mapa de calor de riesgos

Figura 2



Criterios de ponderación utilizados

Tabla 5

Nivel	Probabilidad	Impacto
5 (Muy Alto / Crítico)	Ocorre frecuentemente (ej: >70% en phishing)	Daño irreversible, pérdidas >Q500k, riesgo legal, cierre del negocio
4 (Alto)	Ocorre con cierta frecuencia (anual)	Daño mayor, pérdidas Q100k-Q500k, clientes afectados
3 (Medio)	Ha ocurrido (cada 2-3 años)	Daño moderado, pérdidas Q20k-Q100k, impacto reputacional local
2 (Bajo)	Podría ocurrir en circunstancias extremas	Daño menor, pérdidas <Q20k, recuperable
1 (Muy Bajo)	Casi imposible que ocurra	Impacto insignificante

Plan de tratamiento por prioridad

Tabla 6

Prioridad	Riesgos	Acción	Responsable	Plazo
CRÍTICA (Inmediata)	R-01, R-02	Implementar controles técnicos y de concienciación de forma urgente. No operar sin mitigación. Establecer políticas, procedimientos y herramientas.	Gerente de Operaciones / DevOps	0-3 meses
ALTA (Corto Plazo)	R-03, R-04, R-05, R-06	Reducir riesgo a niveles aceptables.	SGSI / Gerente General	3-6 meses
MEDIA (Mediano Plazo)	R-07, R-08	Implementar controles físicos y de endpoint, monitorear cumplimiento.	DevOps / RRHH	6-12 meses

Políticas de seguridad

Las políticas de seguridad definen las diferentes responsabilidades de los empleados y regulan el uso de los recursos tecnológicos mediante normas y lineamientos para proteger el equipo, la red, los datos sensibles y en general los activos de información.

Política de gestión de contraseñas

Las credenciales correspondientes a sistemas, accesos y activos críticos deberán ser de uso propio y no revelarse con nadie en ninguna circunstancia de manera verbal, escrita o por algún medio electrónico, además de cumplir con los siguientes criterios:

- Ser contraseñas complejas y seguras con las siguientes características:
 - ✓ Contener mínimo 8 caracteres.
 - ✓ Incluir caracteres en mayúsculas y minúsculas.
 - ✓ Incluir signos o dígitos de puntuación.
 - ✓ No incluir nombres propios, familiares, mascotas, ni ningún tipo de información relacionada.
 - ✓ No incluir fechas, ni dígitos numéricos relacionados a fechas de nacimiento propias o de conocidos.
 - ✓ No usar patrones (qwerty, aaabbb, 1234, abc123, etc.), ni palabras predecibles (admin, password, etc.) en la construcción de la contraseña.
- Las contraseñas deben ser actualizadas por lo menos una vez cada 6 meses.
- No almacenar las contraseñas en sistemas informáticos, a excepción de gestores aprobados por la organización.
- No escribir, ni guardar las contraseñas en ningún lugar físico.
- No reutilizar contraseñas en uno o más sistemas y sitios.
- Evitar el uso de funcionalidades “Recordar mi contraseña” y automatización de ingresos, siempre debe ingresar por usuario y contraseña.
- Utilizar métodos de autenticación multifactor (MFA) en sistemas y sitios donde sea posible.

Política de acceso a la información

Se describen las bases para garantizar que solo los usuarios designados tengan acceso a la información sensible a continuación:

- Controlar a cuáles datos puede acceder un usuario en particular.
- No conceder detalles sobre conocimiento técnico a los sistemas de información a ningún usuario que este no requiera.
- Controlar los derechos de usuarios, escritura y creación, modificación y eliminación sobre la información de la organización.

- Se deben deshabilitar inmediatamente todas las cuentas corporativas y accesos con los que cuente un usuario correspondiente a una persona que finalice su vínculo con la empresa.
- Cada usuario es responsable del cuidado y uso dado a sus credenciales de accesos.
- Tolerancia cero a cambios realizados por usuarios no autorizados, cualquier cambio o acceso no autorizados será considerado una violación a la política de seguridad y estará sujeto a las medidas correspondientes.

Política de protección de la información

Se establece el nivel de confidencialidad de la información, criterios de clasificación y restricción de accesos en base a lo siguiente:

Tabla 7

Clasificación de la Información según Nivel de Confidencialidad y Restricción de Acceso

Nivel de confidencialidad	Criterio de clasificación	Restricción de acceso
Pública	Su conocimiento público no puede dañar a la organización de ninguna manera	Información siempre disponible para todo público
Uso interno	El acceso no autorizado podría ocasionar daños menores a la organización	Información disponible para colaboradores internos y terceros seleccionados
Confidencial	El acceso no autorizado podría ocasionar daños considerables a la organización y su reputación	Información disponible solo para colaboradores internos y terceros seleccionados
Confidencial restringida	El acceso no autorizado podría ocasionar de forma irreparable a la organización y su reputación	Información disponible solo para personas específicas dentro de la organización

Nota: Tabla de elaboración propia

- Todo usuario que acceda por motivos laborales a información categorizada como confidencial y confidencial restringida, deberá firmar el acuerdo de confidencialidad.
- La información digital categorizada como confidencial y confidencial restringida deberá permanecer en equipos debidamente protegidos y con claves de acceso.

- La información física categorizada como confidencial y confidencial restringida deberá permanecer bajo llave permanentemente, y utilizada solo por personas autorizadas.
- La información confidencialmente restringida que sea compartida por redes propias o externas deberá ser encriptada y compartir métodos de descifrado por un medio distinto.

Política de prevención contra malware y phishing

Los siguientes lineamientos tienen como finalidad reducir y mitigar amenazas de software malicioso que puedan afectar la seguridad de la información:

- Equipos, servidores y dispositivos que procesan información deberán contar con soluciones de protección antivirus.
- Las soluciones antivirus deben estar autorizadas por el equipo de seguridad y ser actualizadas periódicamente para garantizar su efectividad.
- En los sistemas de red, deben ser implementados firewalls y mecanismos de filtrado que limiten accesos no autorizados.
- Se deben limitar los usuarios a abrir archivos y utilizar dispositivos extraíbles de origen desconocido en equipos de trabajo.
- No abrir enlaces de origen desconocido, especialmente si fueron recibidos por correo electrónico u otros medios digitales.
- No utilizar correos electrónicos, ni cuentas corporativas para uso personal.
- Validar con atención que los remitentes de correos electrónicos recibidos correspondan a personal interno de la empresa o terceros reconocidos y autorizados, antes de abrir cualquier enlace, documento o iniciar cualquier interacción.
- Dar el uso correcto a recursos de Internet por todo el personal, para evitar la contaminación de los activos de la organización a causa de virus, malware, spyware, etc.
- En caso de identificar algún intento de phishing reportarlo al equipo de seguridad inmediatamente.
- En caso de detectar comportamientos anómalos o una posible amenaza de malware, el incidente debe ser reportado inmediatamente al equipo de seguridad y evitar la manipulación del equipo mientras es aislado.

Política para desarrollo de software

Es necesario establecer controles que garanticen la seguridad durante todo el ciclo de vida de desarrollo de los diferentes proyectos.

- El código fuente deberá almacenarse en repositorios seguros con controles de acceso restringido.
- Se deberán realizar revisiones de código antes de integrar cambios a las ramas y versiones principales de las aplicaciones.
- Las dependencias y librerías utilizadas en los proyectos deberán mantenerse actualizadas para evitar vulnerabilidades conocidas.
- Se deberán realizar pruebas de seguridad y validaciones antes de publicar nuevas versiones de las aplicaciones.
- El acceso a los repositorios de código deberá limitarse únicamente al personal autorizado dentro del equipo de desarrollo.

Política de respaldo de la información

La capacidad de recuperación de forma eficiente en caso de pérdida o interrupción es un activo crítico, para lo cual:

- Se deben realizar copias de respaldo de información periódicamente a equipos y servidores identificados como críticos.
- Se deben realizar pruebas periódicas de backup para confirmar la efectividad del proceso de respaldo.
- Los respaldos se deben almacenar de forma segura con controles de acceso y cifrado, restringido únicamente al personal autorizado y designado para ejecutar los procesos de recuperación.

Política de eliminación y destrucción

La información debe manejarse de acuerdo con su ciclo de vida, y una vez que este ciclo finaliza, tomar en cuenta lo siguiente:

- Únicamente el personal designado es responsable de verificar y eliminar datos de los equipos.

- Los datos deben ser eliminados de forma segura, y si no es posible garantizar la seguridad de su eliminación se debe destruir su soporte de almacenaje.
- Los colaboradores que manejan documentos físicos son responsables de la destrucción y no dejar evidencia del soporte en papel. Utilizar los dispositivos correspondientes para destrucción de documentos.

Política de redes y accesos remotos

Se debe garantizar la seguridad de la infraestructura de red de la organización de acuerdo con los siguientes lineamientos:

- Se deben configurar y administrar las redes de forma segura, limitando accesos lógicos y físicos no autorizados.
- El acceso remoto deberá realizarse mediante redes privadas virtuales (VPN).
- La infraestructura de red debe contar con firewall, y controles que permitan el monitoreo y restricción según políticas establecidas.

Política de capacitación y concientización en seguridad

Para fortalecer la cultura de seguridad interna, y garantizar la aplicación de las políticas establecidas por todo el personal de la organización, se define lo siguiente:

- Todo el personal debe recibir capacitación constante de acuerdo con sus funciones y responsabilidades.
- Se deberán recibir las capacitaciones organizadas de forma presencial, en línea, y por medio de los diferentes canales de la organización.
- El personal es responsable de aplicar los conocimientos adquiridos en las capacitaciones recibidas.
- El incumplimiento de las prácticas de seguridad dará lugar a la aplicación de medidas correctivas según la normativa de la empresa.

Política de uso de inteligencia artificial

El uso de herramientas de inteligencia artificial debe realizarse de forma que se puedan aprovechar todos sus beneficios de acuerdo con los siguientes lineamientos:

- Está prohibido el uso de documentos de uso interno, confidenciales y confidenciales restringidos en plataformas públicas y plataformas de IA.

- No se deberá compartir código fuente, credenciales, información de clientes o datos sensibles en plataformas de inteligencia artificial sin la autorización correspondiente.
- La generación de contenido por medio de inteligencia artificial debe realizarse como apoyo al trabajo del usuario y no delegar toda la responsabilidad de este sobre los resultados obtenidos.
- Los usuarios deberán verificar la información generada por herramientas de inteligencia artificial antes de utilizarla en procesos, documentación o desarrollo de software.

Cualquier uso indebido de herramientas de inteligencia artificial que comprometa la seguridad de la información será considerado una violación a las políticas de seguridad de la organización.

Procedimiento de revisión y aprobación de la política de seguridad

Una vez definido todo el alcance de la política, es necesario validar que esté alineada con los objetivos de la empresa y que responda adecuadamente a los riesgos que sido identificados, para ello, se establece el siguiente proceso de revisión y aprobación.

Revisión a nivel técnico

Se realiza la revisión técnica para asegurar que el alcance de la política cubre toda la infraestructura tecnológica y que su aplicación es viable para la organización.

- Se revisan los lineamientos definidos en la política.
- Se evalúa si los controles propuestos ayudan a mitigar los riesgos identificados.
- Se mide el impacto que representa aplicar la política con los procesos actuales.
- Se realizan ajustes o mejoras en caso de ser necesario antes de su aprobación final.

Aprobación de la política de seguridad

Luego de pasar por el proceso de revisión, la política debe ser presentada para su aprobación a la alta directiva por el equipo responsable de seguridad para confirmar que cumple con el objetivo. Una vez la política es aprobada, es documentada como parte del SGSI y se oficializa para ser considerada de cumplimiento obligatorio para todo el personal.

- Se deben comunicar las nuevas políticas a todos los colaboradores para hacerlas de su conocimiento y que puedan cumplir con los lineamientos.
- La política debe ser revisada periódicamente, así como también cuando existan cambios en la infraestructura, procesos o nuevos riesgos sean detectados.

- Cualquier modificación debe seguir nuevamente el proceso de revisión y aprobación que ha sido establecido.

Arquitectura de seguridad

Identificación de aplicaciones críticas

Las aplicaciones críticas son las herramientas utilizadas por el personal de la organización para el desarrollo de software, la documentación técnica, la colaboración entre equipos y la automatización de procesos operativos.

Tabla 8

Aplicaciones críticas dentro de la organización

Aplicación	Descripción
Plataforma de control de versiones de código	Sistema utilizado para almacenar y controlar versiones del código fuente de los proyectos desarrollados por la organización, permitiendo la colaboración entre desarrolladores y el seguimiento de cambios en el software.
Sistema de gestión de proyectos y seguimiento de tickets	Aplicación utilizada para planificar actividades, asignar tareas, registrar incidencias y dar seguimiento al progreso de los proyectos de desarrollo de software.
Plataforma de documentación técnica	Herramienta destinada a almacenar y gestionar documentación relacionada con proyectos, manuales técnicos, procedimientos operativos y conocimiento interno de la organización.
Sistema de integración y despliegue	Plataforma que permite automatizar procesos de compilación, pruebas, validación y despliegue de aplicaciones durante el ciclo de desarrollo de software.
Sistema de análisis de calidad y seguridad del código	Herramienta utilizada para analizar el código fuente de las aplicaciones para detectar errores, vulnerabilidades de seguridad y malas prácticas de programación.
Sistema de gestión de incidencias y soporte técnico	Aplicación utilizada para registrar, gestionar y dar seguimiento a solicitudes de soporte, incidentes técnicos y reportes de fallos en los sistemas.

Plataforma de comunicación y colaboración interna	Herramienta utilizada para facilitar la comunicación entre los miembros de la organización, coordinación de actividades, intercambio de información y trabajo colaborativo.
--	---

Nota: Tabla de elaboración propia

Identificación de sistemas críticos

Los sistemas críticos son la infraestructura tecnológica encargada de ejecutar aplicaciones, almacenar información y gestionar los procesos de la organización.

Tabla 9

Principales sistemas críticos dentro de la organización

Sistema	Descripción
Servidores de desarrollo	Sistemas utilizados para los ambientes de desarrollo donde los desarrolladores realizan pruebas funcionales y la integración de componentes.
Servidores de pruebas	Ambientes destinados a validar las funcionalidades de las aplicaciones antes de su implementación en entornos productivos, permitiendo realizar pruebas de rendimiento y seguridad.
Servidores de producción	Sistemas que alojan las aplicaciones finales utilizadas por clientes o usuarios finales.
Servidores de bases de datos	Sistemas encargados de almacenar y gestionar la información estructurada utilizada por las aplicaciones.
Sistema de gestión de usuarios y accesos	Plataforma para administrar los usuarios, roles y permisos dentro de los sistemas de la organización.
Sistema de respaldo y recuperación de información	Infraestructura para realizar copias de seguridad de los datos críticos de la organización y permitir su recuperación en caso de incidentes o fallos tecnológicos.
Sistema de monitoreo de infraestructura	Plataforma utilizada para supervisar el estado y rendimiento de los sistemas tecnológicos para detectar incidentes o fallos de manera oportuna.

Nota: Tabla de elaboración propia

Identificación de redes críticas

Las redes críticas corresponden a los segmentos de comunicación que permiten la interacción entre usuarios, sistemas y aplicaciones dentro de la infraestructura tecnológica de la organización.

Tabla 10

Redes críticas identificadas dentro de la organización

Red	Descripción
Red corporativa interna	Infraestructura de red utilizada por los empleados para acceder a los sistemas, aplicaciones y recursos tecnológicos de la organización dentro de las instalaciones corporativas.
Red de servidores	Segmento de red dedicado a la comunicación entre servidores de aplicaciones, bases de datos y otros servicios tecnológicos críticos.
Red de acceso remoto seguro	Infraestructura que permite a los colaboradores acceder a los recursos de la organización desde ubicaciones externas mediante mecanismos seguros de conexión remota.
Red de desarrollo	Segmento de red destinado exclusivamente a entornos de desarrollo y pruebas de software, separado de los entornos de producción.
Red de producción	Red utilizada para la operación de las aplicaciones y servicios disponibles para usuarios finales o clientes, donde se ejecutan los sistemas productivos de la organización.
Red de administración tecnológica	Segmento de red reservado para la administración de los dispositivos de infraestructura, servidores y equipos de red por parte del personal que ha sido autorizado.

Nota: Tabla de elaboración propia

PLANTILLA ESTÁNDAR DE POLÍTICA – TECNOSYSTEM S.A.

1. Encabezado del documento

- Nombre de la política
 - Código del documento
 - Versión
 - Fecha de emisión
 - Fecha de última revisión
 - Aprobado por
 - Responsable del documento
 - Clasificación del documento
-

2. Propósito

Se da a conocer:

- ¿Por qué existe la política?
- ¿Qué problema o riesgo busca mitigar?
- ¿Cómo contribuye al SGSI?

Idea de redacción:

“Esta política establece los lineamientos para _____, con el fin de proteger la confidencialidad, integridad y disponibilidad de la información de TecnoSystem S.A.

3. Alcance

Debe indicarse:

- A quién aplica (empleados, contratistas, proveedores).
- Qué activos cubre (sistemas, redes, información, dispositivos).
- Si aplica en modalidad presencial y teletrabajo.

Ejemplo:

“Esta política aplica a todos los colaboradores, proveedores y terceros que tengan acceso a los activos de información de TecnoSystem S.A., independiente de su modalidad de trabajo.

4. Definiciones

Lista de términos clave necesarios para comprender la política.

- Activo de información
 - Incidente de seguridad
 - Usuarios autorizados
 - Datos sensibles
-

5. Marco Normativo / Referencias

Se incluye lo siguiente

- ISO/IEC 27001
- ISO/IEC 27002
- Leyes nacionales aplicables
- Documentos internos

6. Roles y Responsabilidades

Incluye lo siguiente:

- Alta dirección
- Responsable del SGSI
- Área de TI / DevOps
- Colaboradores
- Proveedores

Ejemplo de estructura:

Rol	Responsabilidad
Gerente general	Aprobar la política
Responsable SGSI	Supervisar cumplimiento
Colaboradores	Cumplir lineamientos establecidos

7. Lineamientos generales

Parte fundamental en la que se define lo siguiente:

- Normas obligatorias
- Controles mínimos
- Prohibiciones
- Reglas específicas

Debe de redactar con lenguaje claro y obligatorio:

- “Se debe...”
 - “Está prohibido...”
 - “Es obligatorio...”
-

8. Incumplimiento

Definir:

- Consecuencias disciplinarias
- Acciones correctivas
- Posibles sanciones contractuales

Ejemplo:

“Al incumplir la política establecida podrá derivar en sanciones disciplinarias conforme al reglamento interno de trabajo.”

9. Monitoreo y cumplimiento

Indicar:

- Cómo se verificará el cumplimiento

- Auditorías internas
 - Indicadores
 - Revisión periódica
-

10. Gestión de cambios y control de versiones

Tabla recomendada:

Versión	Fecha	Descripción del cambio	Aprobado por

MANUAL DE PROCEDIMIENTOS DE SEGURIDAD DE LA INFORMACIÓN

TecnoSystem S.A.

1. PRESENTACIÓN

Este manual establece el conjunto de lineamientos, normas y procedimientos adoptados por TecnoSystem S.A. para la protección de sus activos de información, infraestructura tecnológica y recursos físicos, siendo este desarrollador conforme a buenas prácticas internacionales en gestión de seguridad de la información, usando como referencia los lineamientos de ISO/IEC 27001 emitidos por la International Organization for Standardization.

2. OBJETIVO

Crear procedimientos formales que permitan:

- Proteger la confidencialidad, integridad y disponibilidad de la información.
 - Reducir riesgos asociados a amenazas internas y externas.
 - Definir responsabilidades claras en materia de seguridad.
 - Asegurar la continuidad operativa de la organización.
-

3. ALCANCE

El presente manual aplica a:

- El personal administrativo y técnico.
 - Proveedores y terceros con acceso a sistemas.
 - Infraestructura tecnológica (servidores, redes, equipos).
 - Documentación física y digital.
 - Instalaciones físicas de TecnoSystem S.A.
-

4. MARCO NORMATIVO Y REFERENCIAL

Se fundamenta en:

- Buenas practicas de gestión de seguridad de la información.
 - Principios de control interno.
 - Estándares internacionales de seguridad.
 - Normativas internas de TecnoSystem S.A.
-

5. PROCEDIMIENTOS DE SEGURIDAD

5.1.PROCEDIMIENTOS DE CONTROL DE ACCESO LÓGICO

5.1.1. Objetivo

Nivelar el acceso a los sistemas de información para asegurar que el personal autorizado sean los únicos responsables.

5.1.2. Lineamiento

- Los usuarios deberán contar con credenciales únicas e intransferibles.
- Crear, modificar o eliminar usuarios deberá ser autorizado por parte de la gerencia.
- Implementación de autenticación robusta.
- Accesos controlados y revisados semestralmente.
- Cuentas de exempleados serán deshabilitadas inmediatamente.

5.1.3. Responsable

Administrador de Sistemas.

5.2.PROCEDIMIENTO DE GESTIÓN DE CONTRASEÑAS

- Contraseñas con mínimo de 8 caracteres alfanuméricos.
 - Renovación de contraseñas cada 90 días.
 - Bloqueo de cuenta tras 5 intentos fallidos.
 - No se permite la reutilización de las últimas cinco contraseñas.
 - Queda prohibido compartir credenciales.
-

5.3.PROCEDIMIENTO DE SEGURIDAD FÍSICA

5.3.1. Objetivo

Anticipar los accesos no autorizados a las instalaciones, equipos y áreas críticas.

5.3.2. Medidas

- Registro obligatorio de visitantes.
- Uso de identificación institucional visible.
- Acceso restringido al cuarto de servidores.
- Instalación de cámaras de vigilancia.
- Protección eléctrica mediante UPS.

5.3.3. Responsable

Encargado de seguridad física.

5.4.PROCEDIMIENTO DE GESTIÓN DE COPIAS DE SEGURIDAD

5.4.1. Objetivo

Respalda la disponibilidad y recuperación de la información ante incidentes o desastres.

5.4.2. Procedimiento

- Respaldo diario automático de bases de datos y archivos críticos.
- Respaldo externo semanal en medio seguro
- Almacenamiento cifrado de copias.
- Pruebas de restauración trimestrales documentadas.
- Conservación de respaldos.

5.4.3. Responsable

Administrador de TI

5.5.PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD

5.5.1. Objetivo

Establecer un mecanismo formal para la detección, respuesta y recuperación ante incidentes.

5.5.2. Fases Del Procedimiento

- Detección, identificación del incidente por monitoreo o reporte.
 - Notificación, Comunicación al instante al área de TI.
 - Registro, documentación formal del incidente.
 - Contención, Aislamiento del sistema afectado.
 - Erradicación, Eliminación de la causa raíz.
 - Recuperación, Restauración de servicios.
 - Informe Final, Elaboración de reporte con lecciones aprendidas.
-

5.6.PROCEDIMIENTO DE USO ACEPTABLE DE RECURSOS TECNOLÓGICOS

- Todos los equipos y sistemas son exclusivamente para fines laborales.
 - Se prohíbe la instalación de software sin autorización.
 - Se prohíbe el uso de dispositivos externos sin escaneo previo.
 - Se realizará monitoreo del uso de red conforme a políticas internas.
-

5.7.PROCEDIMIENTO DE GESTIÓN DE ACTUALIZACIONES Y PARCHES

- Permisos de actualizaciones automáticas.
 - Revisión de vulnerabilidades mensuales.
 - Parches críticos serán aplicados de forma prioritaria.
 - Todo cambio deberá documentarse.
-

5.8.PROCEDIMIENTO DE CLASIFICACIÓN DE LA INFORMACIÓN

Se clasifica de la siguiente forma:

- Pública
- Uso interno
- Confidencialidad
- Crítica

Todas las categorías tendrán controles de acceso y almacenamiento acordes a su nivel de sensibilidad.

5.9.PROCEDIMIENTO DE SEGURIDAD DE REDES

- Implementación de firewalls perimetrales.
 - Antivirus y antimalware actualizados.
 - Segmentación de red.
 - Accesos remotos únicamente mediante VPN segura.
 - Monitoreo continuo del tráfico de red.
-

5.10. PROCEDIMIENTO DE CAPACITACIÓN Y CONCIENTIZACIÓN

- Capacitaciones anuales de seguridad siendo obligatorias.
 - Simulacros de ataques de ingeniería social.
 - Firma de acuerdos de confidencialidad.
 - Actualización periódica sobre nuevas amenazas.
-

6. RÉGIMEN DISCIPLINARIO

Al incumplir los procedimientos establecidos podrá dar lugar a:

- Amonestaciones escritas.
 - Suspensión temporal.
 - Terminación contractual.
 - Acciones legales según corresponda.
-

7. REVISIÓN Y ACTUALIZACIÓN

El presente manual debe ser revisado anualmente o cuando:

- Se produzcan cambios tecnológicos relevantes.
- Ocurra un incidente significativo.
- Existan modificaciones normativas aplicables.

DOCUMENTACIÓN DE CONFIRMACIÓN DE INTEGRACIÓN DE PROCEDIMIENTOS

TecnoSystem S.A.

En la ciudad de Guatemala, a la fecha de emisión del presente documento, la Gerencia General y el Área de Tecnología de la Información de TecnoSystem S.A. aplica la constancia formal de que los procedimientos establecidos en el Manual de Seguridad de la información han sido implementados e incorporados en las operaciones regulatorias de la organización.

Integrar los dichos procedimientos ha sido realizado conforme a las buenas prácticas del Sistema de Gestión de Seguridad de la Información, tomando como referencia los lineamientos de ISO/27001.

Se reafirma que:

- Los controles de acceso lógico se encuentran activos en los sistemas institucionales.
- Las contraseñas están configuradas y operativas por las políticas.
- El procedimiento de copias de seguridad se ejecuta de forma automatizada.
- La gestión de incidentes cuenta con formato de registro y seguimiento.
- Las medidas de seguridad física están aplicadas en áreas críticas.
- El personal ha sido notificado y capacitado respecto a las políticas vigentes.

Por lo que, se realizó mediante una verificación interna que los procedimientos no solo están documentados, más bien forman parte del funcionamiento diario de la empresa y considera obligatorio para el personal.

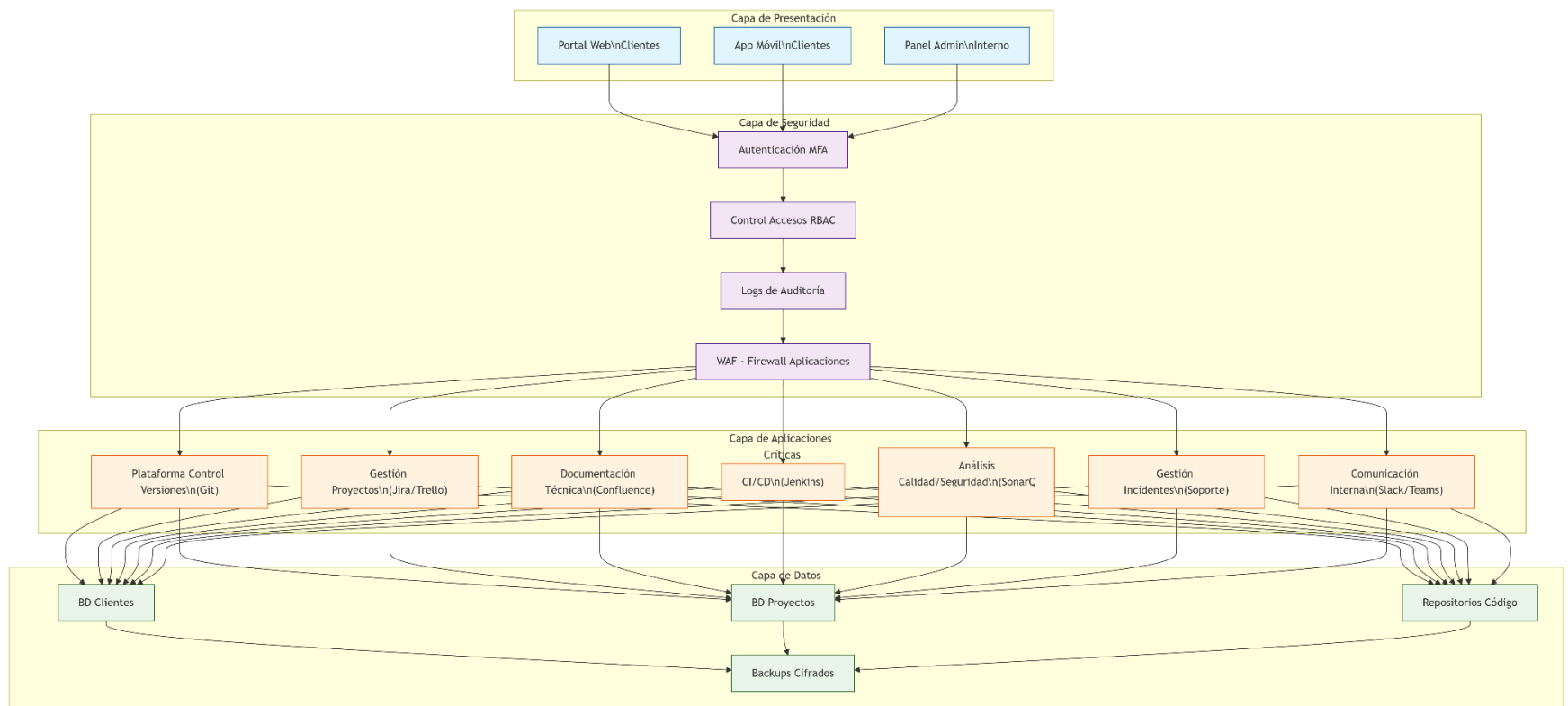
La seguridad de la información ha sido integrada como componente transversal en los procesos administrativos, operativos y tecnológicos de TecnoSystem S.A.

Esta documentación se emite como evidencia formal de integración y podrá ser utilizado como respaldo ante revisiones internas o auditorías externas.

Diagrama de la arquitectura de la seguridad

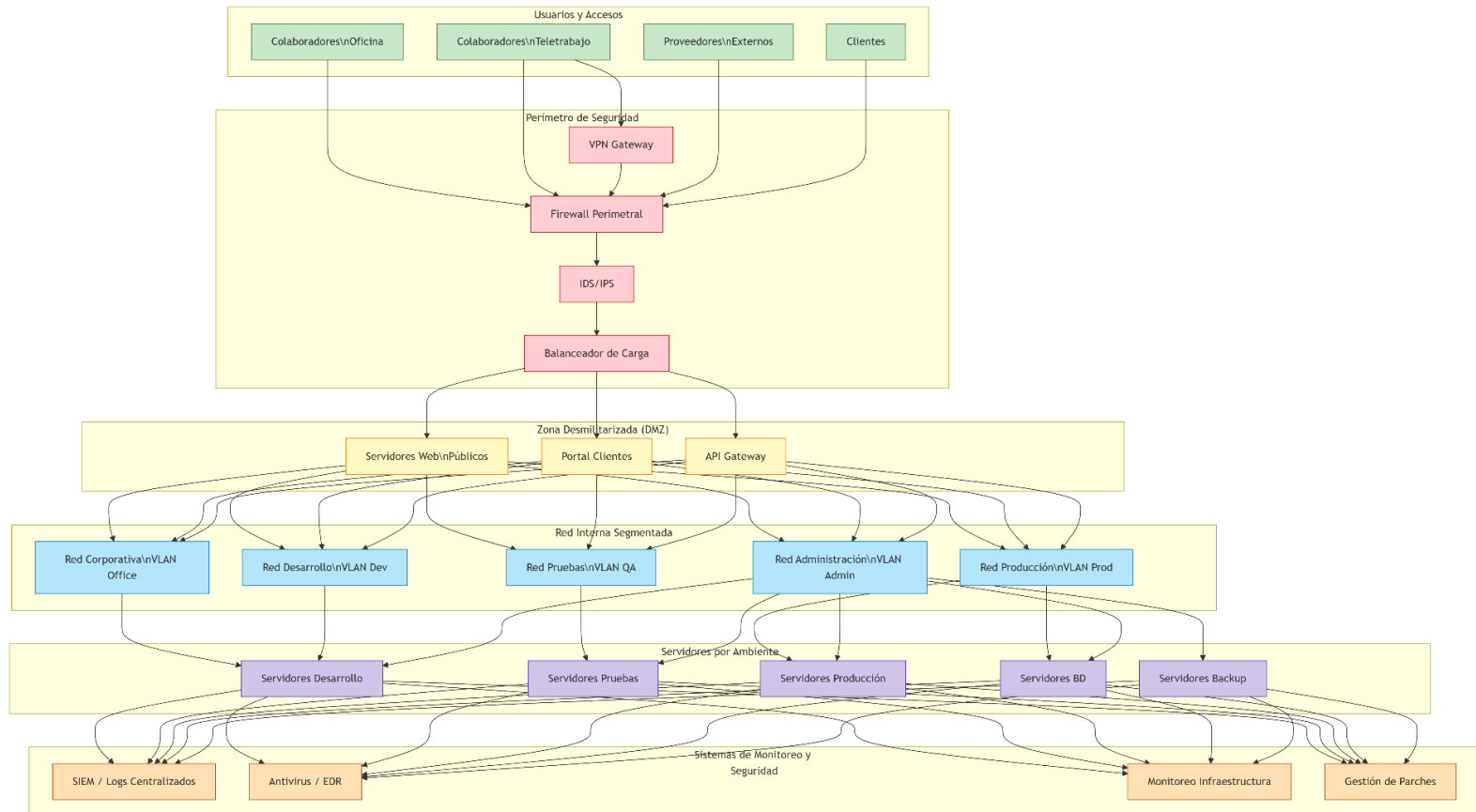
Arquitectura de aplicaciones críticas

Figura 3



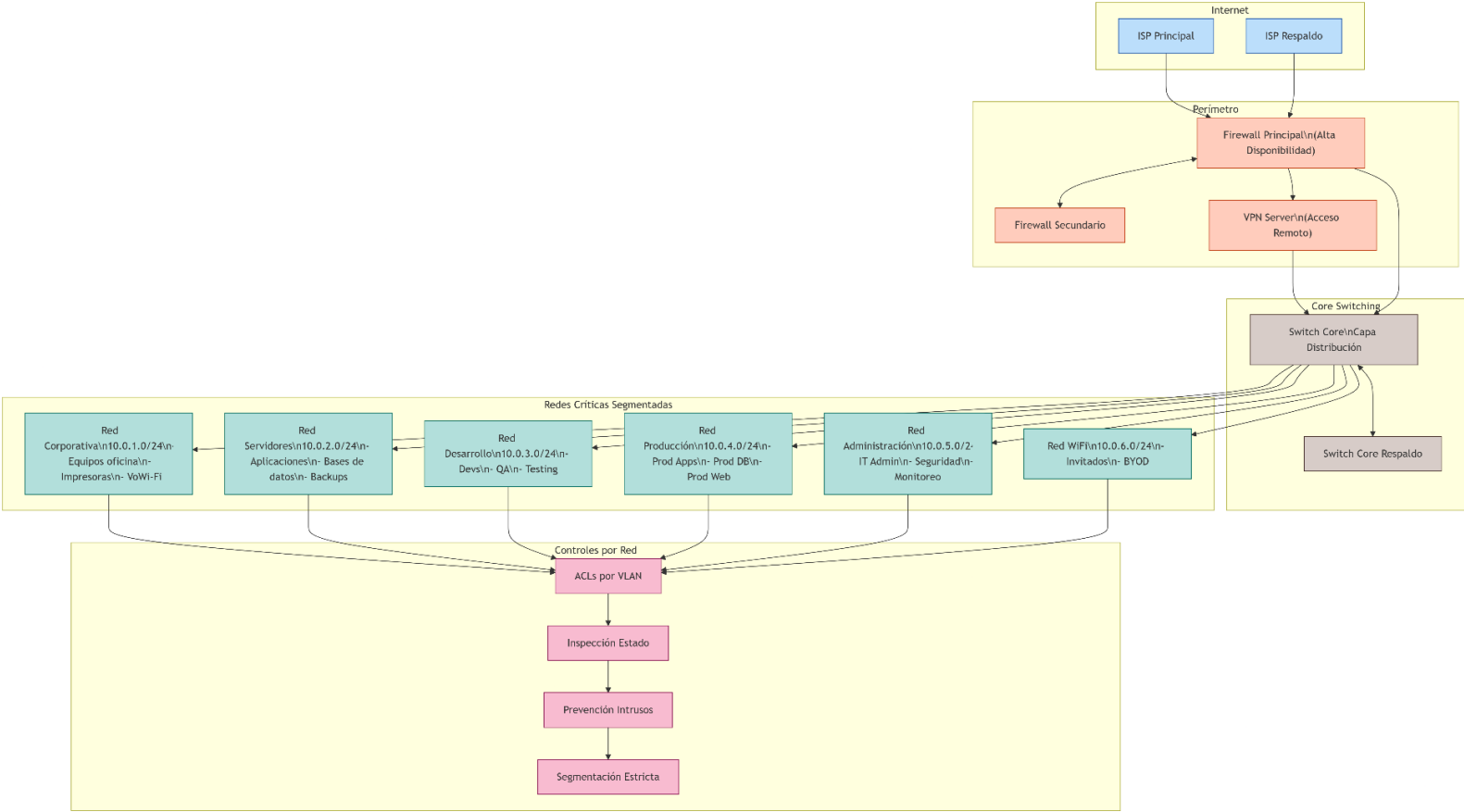
Arquitectura de sistemas e infraestructura

Figura 4



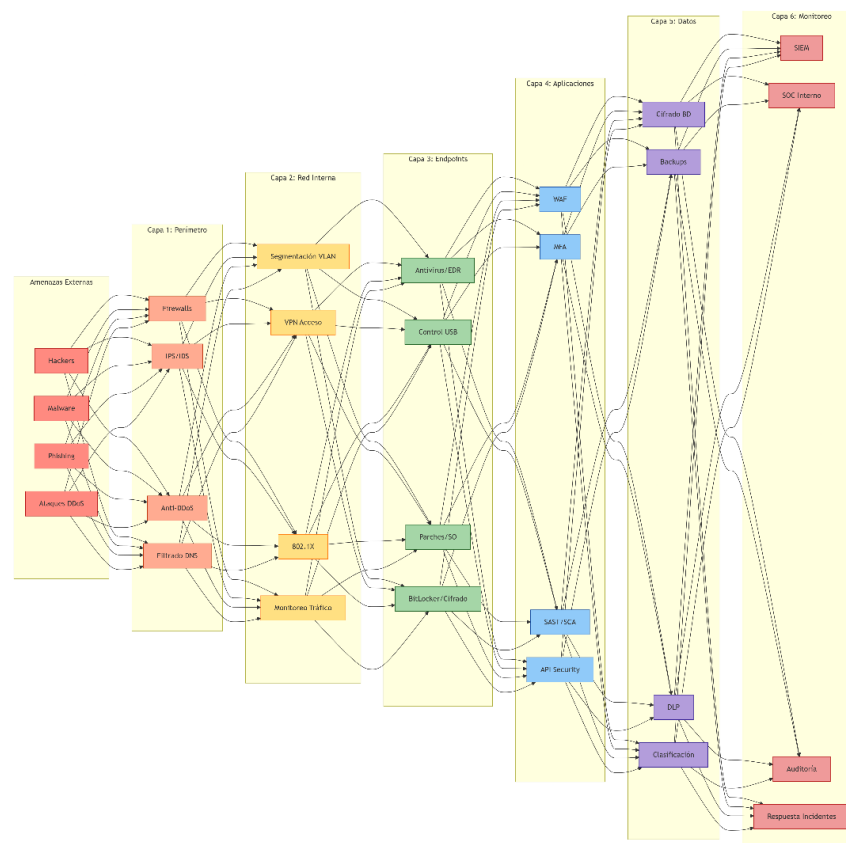
Arquitectura de redes críticas

Figura 5



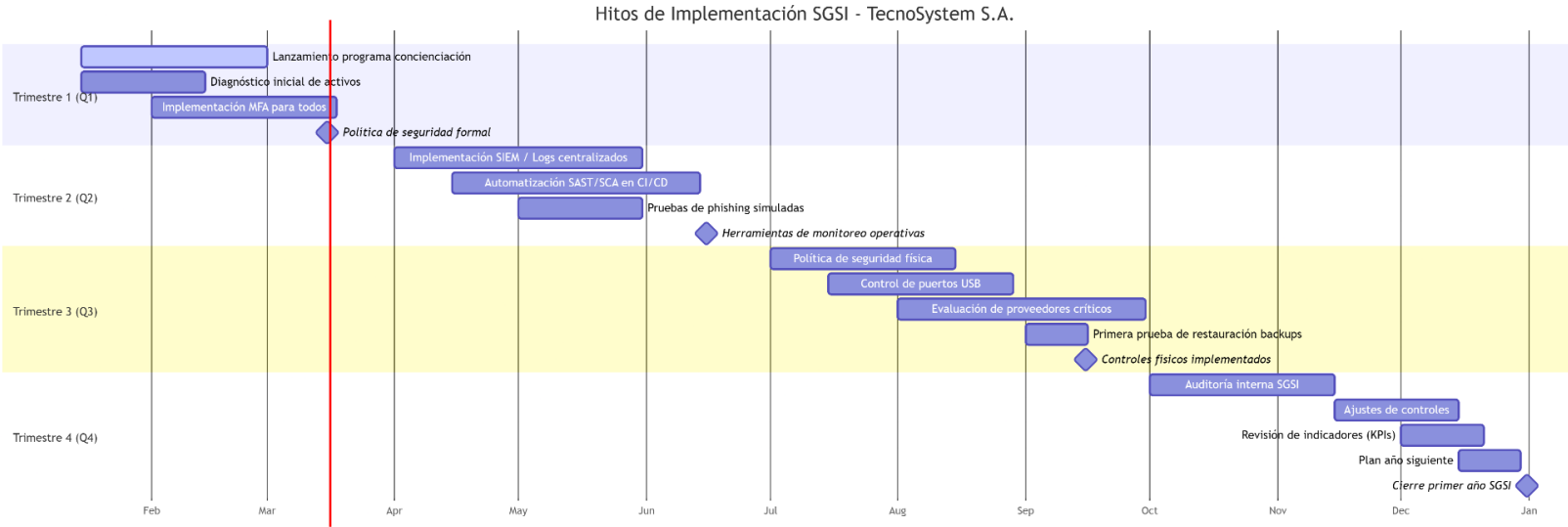
Arquitectura de seguridad end-to-end (visión completa)

Figura 6



Hitos y cronograma de implementación

Figura 7



Revisión por expertos y aprobación

El proceso de aprobación formal de la arquitectura de la seguridad elaborada para el SGSI de TecnoSystem S.A., requiere de una revisión por expertos aplicable de acuerdo a lo siguiente:

Roles participantes

Revisores expertos

Se consideran expertos para la revisión técnica de los diagramas a:

- **Responsable del SGSI / líder en seguridad de la información:** Revisión de cobertura de controles, alineación con políticas y procedimientos del SGSI.
- **Área de DevOps / Infraestructura:** Revisión de representación de redes, sistemas, segmentación y controles técnicos (firewall, VPN, ambientes).
- **Líder de desarrollo o representante técnico:** Revisión del diagrama de entorno de desarrollo (repositorios, CI/CD, ambientes) y de control de acceso en entornos de desarrollo.

Aprobador

La aprobación formal de los diagramas corresponde a la alta dirección, en representación de TecnoSystem S.A. una vez satisfecha la revisión por expertos. Pueden sumarse otros revisores si la organización lo considera necesario.

Criterios de revisión

Los expertos evaluarán los diagramas con base en los siguientes criterios:

Tabla 11

Criterios de revisión de arquitectura de seguridad

Criterio	Descripción
Alineación con activos críticos	Los diagramas reflejan las aplicaciones, sistemas y redes críticas identificadas en el inventario (Tablas 8, 9 y 10).

Consistencia con políticas y procedimientos	Los controles representados (MFA, segmentación, IAM, respaldo, etc.) están alineados con las políticas de seguridad y el manual de procedimientos del SGSI.
Compleitud	Cada diagrama incluye los elementos necesarios para entender la arquitectura en su ámbito (general, red, desarrollo, control de acceso) sin omisiones relevantes.
Claridad y usabilidad	La representación es comprensible para los roles que deban usar los diagramas (operaciones, auditoría, gerencia).
Adecuación al contexto	La arquitectura representada es coherente con el tamaño, modelo híbrido y tipo de servicios (SaaS) de la organización.

Nota: Tabla de elaboración propia

Cada revisor puede consignar observaciones o recomendaciones de mejora. Si existen observaciones de fondo, se deben incorporar ajustes a los diagramas antes de someterlos a aprobación de la alta dirección.

Proceso de revisión y aprobación

1. **Elaboración:** El responsable del SGSI (o quien designe la organización) elabora o actualiza los diagramas de arquitectura de la seguridad.
2. **Distribución:** Se envían los diagramas y este documento de criterios a los revisores expertos (SGSI, DevOps / Infraestructura, Desarrollo).
3. **Revisión técnica:** Cada revisor revisa los diagramas conforme a los criterios de revisión y documenta los resultados.
4. **Incorporación de observaciones:** Si hay observaciones que impliquen cambios en los diagramas, se realizan los ajustes y se vuelve a registrar el resultado en el registro.

5. **Aprobación:** Una vez cerrada la revisión por expertos con resultado favorable, los diagramas se someten a la alta dirección para su aprobación formal, la cual se deja constancia en el acta de aprobación.

Documento de instrucciones de seguridad

Objetivos de documento de seguridad

Este documento establece las directrices fundamentales para proteger la integridad, confidencialidad y disponibilidad de los activos digitales y físicos. La seguridad no es solo un documento o leyes técnicas sino una cultura de prevención que involucra a cada miembro de la organización por el bienestar común.

Algunos objetivos de dicho documento son:

- Garantizar la continuidad del negocio
- Proteger el patrimonio
- Cumplimiento legal y normativo
- Reducción del riesgo humano

POLÍTICA GLOBAL DE SEGURIDAD DE LA INFORMACIÓN - TECNOSYSTEM S.A.

Area de identidad y control de accesos

1. Gestión de contraseñas seguras
 - a. **Regla:** Todo acceso debe usar contraseñas complejas (mínimo 12 caracteres, mezcla de tipos) y es obligatorio activar la Autenticación de Doble Factor para evitar ingresos no autorizados. Queda estrictamente prohibido el uso de contraseñas basadas en información personal, palabras de diccionario o secuencias lógicas.
 - b. **Actividad:** Instalar y usar un gestor de contraseñas autorizado por la empresa para crear claves únicas por cada sitio, evitando anotar o repetir contraseñas en diferentes cuentas.
2. Autenticación de múltiple factor
 - a. **Regla:** Todo inicio de sesión en sistemas debe exigir al menos dos factores de verificación distintos (contraseña + código autenticación) para confirmar la identidad del usuario y bloquear accesos no autorizados.

- b. **Actividad:** Configurar una aplicación de autenticación móvil como Microsoft Authenticator, DUO mobile, etc.... para recibir códigos dinámicos o notificaciones "push" al intentar entrar a cuentas corporativas o correos electrónicos.

Area de manejo de información confidencial

3. Clasificación de datos

- a. **Regla:** Toda información debe ser etiquetada según su nivel de sensibilidad sea pública, confidencial o interna para determinar quién tiene permiso de verla y qué medidas de seguridad se deben aplicar a ellas.
- b. **Actividad:** Aplicar etiquetas de clasificación en documentos online o bien correos antes de guardarlos, asegurando que los archivos marcados como "confidenciales" se guarden únicamente en carpetas con acceso restringido.

4. Cifrado de información

- a. **Regla:** Obligatorio cifrar toda información sensible tanto al almacenarla localmente como al enviarla por red, garantizando que los datos sean imposibles de leer para cualquier persona que no posea la clave de descifrado.
- b. **Actividad:** Activar el cifrado de disco completo como bitlocker en laptops y memorias USB de la institución para asegurar que en caso de pérdida o robo, la información no pueda ser extraída del disco.

Area de seguridad en equipos y endpoints

5. Control de dispositivos extraíbles

- a. **Regla:** Prohibición de conectar memorias USB, discos duros externos o dispositivos personales no autorizados por el departamento de TI con el fin de evitar la fuga de información y la entrada de posibles virus.
- b. **Actividad:** Implementar un software de endpoint security que bloquee por defecto los puertos USB del equipo y solo permita el funcionamiento de dispositivos que tengan un número de serie previamente registrado con autorización de la empresa.

6. Parcheado y actualizaciones

- a. **Regla:** Toda aplicación y/o sistema operativo debe mantenerse en su versión más reciente para corregir vulnerabilidades de seguridad que podrían ser explotadas por atacantes, esto está a cargo del área de Seguridad TI.
- b. **Actividad:** Se deben configurar las actualizaciones automáticas y forzadas en el equipo y programar un reinicio semanal para asegurar que los parches de seguridad se instalen y apliquen correctamente sin interrumpir el trabajo.

Area de seguridad en el trabajo

7. VPN

- a. **Regla:** Obligatorio conectarse a la VPN corporativa siempre que se trabaje fuera de la oficina o se utilicen redes Wi-Fi AUTORIZADAS, para crear un túnel que proteja el tráfico de datos.
- b. **Actividad:** Abrir el cliente de VPN (PaloAlto, Forticlient) e iniciar sesión con tus credenciales antes de acceder a correos o aplicaciones internas de la empresa.

8. Seguridad de router

- a. **Regla:** Se debe asegurar el acceso al router mediante el cambio de credenciales por defecto, la desactivación de protocolos inseguros y el uso de estándares de cifrado WPA3 para evitar intrusiones en la red.
- b. **Actividad:** Ingresar al panel de administración del router para actualizar el firmware a su última versión.

Area de prevención de ingeniería social

9. Protocolos anti-pishing

- a. **Regla:** Ningún colaborador debe hacer clic en enlaces o descargar archivos de correos electrónicos externos, ni proporcionar información sensible o confidencial a través de mensajes. Verifica siempre si son de fuentes legítimas.
- b. **Actividad:** Aplicar correos para reportar y verificar si dicho correo es auténtico antes de realizar cualquier acción.

10. Protección Vishing

- a. **Regla:** Prohibición de proporcionar datos sensibles, códigos de verificación etc. basadas únicamente en una llamada.
- b. **Actividad:** Verificar legitimidad de llamada por medio de área de la institución.

Area de desarrollo seguro

11. Protección código fuente

- a. **Regla:** El código fuente debe almacenarse en repositorios privados con control de acceso.
- b. **Actividad:** Bloquear automáticamente cualquier commit de código que contenga información sensible o vulnerable.

12. Protección vulnerabilidades e inyección sql

- a. **Regla:** Todo desarrollo debe implementar la validación del lado del servidor prohibiendo el uso de consultas dinámicas que incluyan datos del usuario directamente en la base de datos para evitar el robo o borrado de información.
- b. **Actividad:** Utilizar consultas preparadas o procedimientos almacenados con parámetros en todo el código, asegurando que el motor de la base de datos trate los datos del usuario como simple texto.

Area de seguridad física y entorno

13. Políticas de lugar seguro y limpio

- a. **Regla:** Todo espacio de trabajo debe mantenerse libre de información sensible en formato físico y los equipos deben estar bloqueados siempre que el usuario no se encuentre en su lugar.
- b. **Actividad:** Implementar la técnica de "escritorio vacío" al final del día, guardar bajo llave todo documento sensible o confidencial y activar el bloqueo de pantalla inmediato.

14. Controles de acceso

- a. **Regla:** El acceso a sistemas y datos debe basarse en roles y los permisos que se otorgan de forma individual deben revocarse inmediatamente cuando el colaborador cambia de funciones o deje la organización.
- b. **Actividad:** Realizar una revisión o barrido trimestral en donde el administrador del sistema elimine cuentas inactivas y ajuste los permisos de los usuarios que tengan accesos no autorizados.

Area de gestión de incidentes

15. Reportes de anomalías

- a. **Regla:** Todo colaborador tiene la obligación de notificar de inmediato cualquier comportamiento inusual en sus equipos para activar el protocolo de respuesta.
- b. **Actividad:** Utilizar un único canal para reportar incidentes.

16. Procedimientos anti robos

- a. **Regla:** En caso de robo o extravío de cualquier equipo corporativo el usuario debe reportarlo de forma inmediata para proceder con el bloqueo remoto.
- b. **Actividad:** Aun así se cuente con bitlocker, se debe realizar el protocolo de borrado remoto a través de la consola de administración para eliminar toda la información confidencial y que no se quede expuesta.

Area de RRHH

17. Acuerdos de confidencialidad

- a. **Regla:** Todo nuevo colaborador, practicante o proveedor externo debe firmar un acuerdo de no divulgación antes de recibir acceso a cualquier sistema o información sensible.
- b. **Actividad:** Incluir en el proceso de inducción la firma del contrato de confidencialidad y realizar una sesión de sensibilización sobre qué información se considera sensible y cual no.

18. Offboarding

- a. **Regla:** Se debe ejecutar la eliminación inmediata de todos los accesos físicos y lógicos.
- b. **Actividad:** Desactivación de la cuenta en el active directory antes de que el colaborador abandone las instalaciones.

Matriz de roles y responsabilidades

Tabla 12

Actividad	Usuario Final	Departamento IT	Oficial de Seguridad (CISO)
Crear contraseñas seguras	Ejecuta	Monitorea	Audita
Reportar incidentes	Ejecuta	Resuelve	Analiza
Actualizar software	Recibe	Ejecuta	Supervisa
Clasificar información	Ejecuta	Provee herramientas	Define políticas

Glosario

Activo de Información: Todo dato o sistema que tiene valor para la empresa (ej. bases de datos, laptops).

Malware: Software malicioso diseñado para infiltrarse o dañar un equipo (virus, troyanos).

Phishing: Técnica de engaño mediante correos falsos para robar contraseñas.

Cifrado: Proceso de convertir información en un código secreto para que solo el destinatario pueda leerlo

Formato de Validación de Políticas de Seguridad

ID del Documento: POL-SEG-2026-001

Fecha de Revisión: 04/03/2026

Versión: 1.0

1. Resumen de Revisión Técnica

El equipo de Seguridad de la Información ha auditado los controles descritos en este manual, confirmando que se alinean con los Objetivos del documento de seguridad:

- Continuidad del negocio: Protocolos de reporte y anti-robo validados.
- Protección del patrimonio: Cifrado y seguridad de código fuente verificados.
- Cumplimiento legal: Estándares de NDA y Offboarding alineados a la normativa.
- Reducción del riesgo humano: Protocolos de Ingeniería Social robustecidos.

2. Matriz de Conformidad

Área de Control	Estado de Validación	Observaciones Técnicas
Seguridad Física (Lugar Limpio)	Aprobado	Cumple con política de escritorio limpio.
Control de Acceso (RBAC)	Aprobado	Basado en el principio de mínimo privilegio.
Cifrado y SQL Injection	Aprobado	Estándares AES-256 y Consultas Preparadas.
Gestión de RRHH (NDA/Offboarding)	Aprobado	Procesos vinculantes legalmente.

3. Dictamen de Seguridad

Dictamen: ☒ Aprobado ☐ Aprobado con Observaciones ☐ Rechazado

4. Firmas de Validación

Responsable de Seguridad (CISO/TI)

Firma: _____

Nombre: Ing. Adrián Valles Casarín

Fecha: 05/03/2026

Responsable de Cumplimiento / Legal

Firma: _____

Nombre: Lic. Elena Portillo Herrera

Fecha: 05/03/2026

Checklist y formularios diseñados y documentados.

INS-SEC-01 — Instrucciones de Seguridad para Usuarios

Empresa: TecnoSystem S.A.

Clasificación del documento: Interno

Versión: 1.0

Fecha de emisión: ____ / ____ / ____

Elaboró: _____ (Responsable SGSI)

Revisó: _____ (DevOps/Seguridad)

Aprobó: _____ (Gerencia)

Control de versiones

Versión	Fecha	Descripción del cambio	Elaboró	Revisó	Aprobó
1.0	2026	Emisión inicial			

Objetivo: Establecer las reglas y procedimientos mínimos de seguridad que deben cumplir todos los usuarios para proteger: datos de clientes, código fuente, diseños, y la continuidad operativa.

Alcance: Aplica a: colaboradores, consultores y terceros con acceso a equipos, correo, repositorios, VPN, bases de datos o plataformas de TecnoSystem S.A.

Responsabilidades

Usuarios: cumplir las reglas y reportar incidentes.

Soporte TI/DevOps: aplicar controles técnicos (parches, antivirus, accesos).

SGSI: mantener el documento, capacitar y auditar cumplimiento.

Gerencia: aprobar y respaldar el cumplimiento.

Reglas y procedimientos de seguridad

Crear y usar contraseñas seguras:

- ✓ Usa contraseñas de mínimo 12 caracteres.
- ✓ Combinar mayúsculas, minúsculas, números, símbolos o caracteres especiales.
- ✓ Prohibido usar: tu nombre, fechas, “123456”, “password”, “admin”, “TecnoSystem”.
- ✓ Prohibido reutilizar contraseñas entre sistemas.
- ✓ Cambia contraseñas de todos las cuantas cada 90 días.
- ✓ Si sospechas que tu contraseña fue robada: cámbiala de inmediato y repórtalo.
- ✓ MFA (doble verificación) obligatorio en correo, VPN, repositorios, nube y paneles administrativos.
- ✓ No compartas contraseñas por chat, correo o llamadas.
- ✓ No guardes contraseñas en papel, notas, archivos TXT o capturas.

Procedimiento rápido (si olvidaste o sospechas robo):

Paso 1: Cambia la contraseña (si aún puedes).

Paso 2: Activa/verifica MFA.

Paso 3: Reporta el incidente usando FORM-INC-01.

Cómo manejar información confidencial.

- ✓ Clasificación práctica (para usuarios):
- ✓ Pública: se puede compartir sin riesgo (solo si está aprobada).
- ✓ Interna: solo dentro de la empresa.
- ✓ Confidencial: datos de clientes, contratos, información operativa sensible.
- ✓ Restringida/Crítica: código fuente, diseños, llaves/tokens, BD productiva.

Reglas obligatorias:

- ✓ Trata los datos del cliente como Confidencial por defecto.

- ✓ Código y diseños son Restringidos: solo personal autorizado.
- ✓ No envíes datos del cliente por WhatsApp personal o redes sociales.
- ✓ No subas archivos de trabajo a Drive/Dropbox personal.
- ✓ No compartas documentos “públicos” o “cualquiera con el enlace”.
- ✓ Usa permisos por rol (solo quien lo necesita).
- ✓ No copies bases de datos productivas a equipos personales.
- ✓ No uses USB desconocidos; solo USB autorizado y justificado.
- ✓ Evita imprimir información sensible; si imprimes, resguarda y destruye al finalizar.

Procedimiento rápido (si necesitas compartir un archivo sensible):

Paso 1: Confirma que el destinatario está autorizado.

Paso 2: Usa canal corporativo autorizado.

Paso 3: Otorga permiso mínimo (lectura si basta).

Paso 4: Registra evidencia si aplica (ticket/correo).

Qué hacer si hay un incidente de seguridad

- ✓ Ejemplos de incidentes: phishing, malware, USB sospechoso, fuga de datos, acceso raro, pérdida/robo de equipo, caída sospechosa.
- ✓ Reglas obligatorias:
- ✓ Si recibes correo sospechoso: no abras enlaces/adjuntos.
- ✓ Si hiciste clic o descargaste algo: repórtalo de inmediato.
- ✓ No borres evidencia (correo, capturas, logs).
- ✓ Sigue instrucciones de SGSI/DevOps (aislar equipo, cambiar contraseñas, revocar accesos).

Procedimiento paso a paso:

Paso 1: Detén la actividad sospechosa (no sigas navegando).

Paso 2: Guarda evidencia (capturas, correo, hora).

Paso 3: Reporta con FORM-INC-01.

Paso 4: Espera indicaciones del equipo de seguridad/DevOps.

Cómo usar los equipos de la empresa (computadoras y recursos).

- ✓ No desactives antivirus/EDR ni firewall.
- ✓ Mantén el sistema operativo y aplicaciones actualizadas.
- ✓ Bloquea pantalla al levantarte (Win + L).
- ✓ No instales software sin autorización (ticket/solicitud).
- ✓ No prestes equipo corporativo a familiares/terceros.
- ✓ No conectes USB desconocidos.
- ✓ Reporta pérdida/robo del equipo de inmediato.

Aceptación y cumplimiento

Declaro haber leído y comprendido este documento y me comprometo a cumplirlo.

Nombre: _____ Firma: _____ Fecha: _____

Aprobaciones

Revisó - DevOps/Seguridad: _____ Firma: _____ Fecha: _____

Aprobó - Gerencia: _____ Firma: _____ Fecha: _____

CHECK-SEC-01 - Checklist Mensual de Cumplimiento de Seguridad.

Empresa: TecnoSystem S.A.

Versión: 1.0

Frecuencia: Mensual

Responsable de aplicar: Soporte TI / SGSI

Área evaluada: _____

Fecha: ____ / ____ / ____

Instrucciones de uso:

- Marcar Sí o No.
- Si es No, anotar la acción correctiva y fecha compromiso.
- Adjuntar que tipo de evidencia y donde se almaceno y el responsable (captura, ticket, reporte).

Checklist de Cumplimiento de Seguridad - Sí/No.

#	Descripción	Sí	No	Observación	Acción correctiva	Fecha compromiso
1	¿Las computadoras tienen antivirus/EDR activo?					
2	¿El antivirus/EDR está actualizado?					
3	¿El sistema operativo tiene parches/updates al día?					
4	¿El firewall del equipo está activo?					
5	¿El usuario tiene MFA activo en correo?					
6	¿El usuario tiene MFA activo en repositorios y herramientas críticas?					
7	¿Se cambian contraseñas cada 90 días en sistemas críticos?					
8	¿Las contraseñas cumplen mínimo 12 caracteres?					
9	¿No se comparten contraseñas por chat/correo/llamada?					
10	¿No existen contraseñas en notas/TXT/papel/capturas?					

11	¿Los archivos sensibles están protegidos por permisos (no públicos)?					
12	¿No se usan nubes personales para archivos del trabajo?					
13	¿No se envían datos de clientes por WhatsApp/chats personales?					
14	¿No se copian datos productivos a equipos personales?					
15	¿Se bloquea la pantalla al levantarse (Win+L)?					
16	¿No se instala software sin autorización?					
17	¿No se conectan USB desconocidos o no autorizados?					
18	¿Se reportan correos sospechosos (phishing) al canal definido?					
19	¿Los incidentes se reportan con FORM-INC-01 cuando ocurren?					
20	¿Se completó la capacitación/recordatorio de seguridad del mes?					

Resumen:

Total, Sí: ____ / 20 Total, No: ____ / 20

Comentarios generales:

Responsable revisión: _____ Firma: _____ Fecha: _____

Responsable SGSI: _____ Firma: _____ Fecha: _____

FORM-INC-01 - Formulario de Reporte de Incidente de Seguridad

Empresa: TecnoSystem S.A.

Versión: 1.0

Folio: _____

Fecha: ____ / ____ / ____ / **Hora:** _____

Datos del reportante

Usuario (Nombre): _____

Correo corporativo: _____

Área/Departamento: _____

Teléfono/Extensión: _____

Ubicación: ☐ Oficina ☐ Remoto ☐ Otro: _____

Equipo afectado (ID/Nombre): _____

Tipo de incidente

☐ Phishing / correo falso.

☐ Malware / virus.

☐ USB sospechoso

☐ Acceso no autorizado

☐ Pérdida o robo de equipo

☐ Fuga de información, datos cliente / código / otros.

☐ Vulnerabilidad detectada

☐ Caída o comportamiento anormal del sistema

☐ Otro: _____

Descripción del incidente

¿Qué ocurrió? (detalle):

¿Cuándo ocurrió? (fecha/hora aproximada):

Sistemas involucrados: ☐ Correo ☐ Repo ☐ VPN ☐ SaaS ☐ BD ☐ Otro:

Evidencia disponible

☐ Capturas ☐ Correo ☐ Logs ☐ Archivo ☐ URL ☐ Otro

Detalle / ubicación de evidencia:

Acción tomada

Acción tomada por el usuario (antes de reportar):

Acción tomada por Soporte/DevOps (si ya inició):

Impacto estimado

☐ Bajo ☐ Medio ☐ Alto ☐ Crítico

¿Afectó clientes o datos sensibles? ☐ Sí ☐ No

Detalle:

Seguimiento (uso SGSI/DevOps)

Responsable asignado: _____

Estado: ☐ Abierto ☐ En proceso ☐ Cerrado

Causa preliminar: _____

Lecciones aprendidas:

Fecha de cierre (si aplica): ____ / ____ / ____

Firma: _____

Firma SGSI/DevOps: _____

FORM-ACC-01 - Formulario de Solicitud de Acceso a Sistemas

Empresa: TecnoSystem S.A.

Versión: 1.0

Folio: _____

Fecha: ____ / ____ / ____

Datos del solicitante

Usuario (Nombre): _____

Correo: _____

Rol/Puesto: _____

Área: _____

Jefe inmediato: _____

Acceso solicitado

☐ Correo corporativo

☐ VPN / acceso remoto

☐ Repositorio Git (código)

☐ CI/CD

☐ Plataforma SaaS (admin)

☐ Base de datos (solo si aplica)

☐ Carpeta de diseños/documentación

☐ Herramienta de soporte/tickets

☐ Otro: _____

Nivel de acceso requerido

☐ Lectura ☐ Edición ☐ Administrador (requiere justificación)

Justificación

Duración del acceso

☐ Permanente ☐ Temporal hasta: ____ / ____ / ____

Aprobaciones

Jefe inmediato: _____ Firma: _____ Fecha: ____ / ____ / ____

Dueño del sistema (DevOps/Líder): _____ Firma: _____ Fecha: ____ / ____ / ____

Validación SGSI: _____ Firma: _____ Fecha: ____ / ____ / ____

Confirmación (TI/DevOps)

Acceso otorgado: ☐ Sí ☐ No

MFA activado: ☐ Sí ☐ No

Fecha de alta: ____ / ____ / ____

Observaciones: _____

Firma TI/DevOps: _____

FORM-AUD-01 - Formulario de Auditoría de Seguridad

Empresa: TecnoSystem S.A.

Versión: 1.0

Folio: _____

Fecha: ____ / ____ / ____

Auditor: _____

Datos generales

Área auditada: _____

Responsable del área: _____

Periodo evaluado: Desde ____ / ____ / ____ hasta ____ / ____ / ____

Tipo de auditoría: ☐ Mensual ☐ Trimestral ☐ Por incidente ☐ Especial

Alcance revisado

☐ Contraseñas y MFA

☐ Antivirus/actualizaciones

☐ Manejo de información confidencial

☐ Uso de equipos corporativos

☐ Reporte de incidentes

☐ Accesos a sistemas (mínimo privilegio)

☐ Otros: _____

Resultado del checklist - CHECK-SEC-01

Total Sí: ____ / 20

Total No: ____ / 20

Principales incumplimientos: _____

Hallazgos:

Hallazgo 1:

Severidad: ☐ Baja ☐ Media ☐ Alta ☐ Crítica

Evidencia: _____

Acción correctiva: _____

Responsable: _____ Fecha compromiso: ____ / ____ / ____

Hallazgo 2:

Severidad: ☐ Baja ☐ Media ☐ Alta ☐ Crítica

Evidencia: _____

Acción correctiva: _____

Responsable: _____ Fecha compromiso: ____ / ____ / ____

Hallazgo 3:

Severidad: ☐ Baja ☐ Media ☐ Alta ☐ Crítica

Evidencia: _____

Acción correctiva: _____

Responsable: _____ Fecha compromiso: //2026

Resultado general

☐ Cumple ☐ Cumple parcialmente ☐ No cumple

Firmas

Auditor: _____ Firma: _____ Fecha: ____ / ____ / ____

Responsable del área: _____ Firma: _____ Fecha: ____ / ____ / ____

Responsable SGSI: _____ Firma: _____ Fecha: ____ / ____ / ____

Aprobación Gerencia: _____ Firma: _____ Fecha: ____ / ____ / ____

Implementación de un sistema para la aplicación de checklist y formularios.

Objetivo del documento

Este documento describe la implementación de un sistema que permita a TecnoSystem S.A. aplicar, registrar y dar seguimiento a los checklist y formularios definidos en el SGSI. Se establece qué debe hacer el sistema, para quién y con qué criterios, de modo que la organización pueda materializarlo con la herramienta que considere más adecuada (formularios en línea, intranet, suite de cumplimiento, etc.).

Alcance del sistema

El sistema debe dar soporte a la aplicación de los siguientes documentos ya diseñados y documentados en el SGSI:

Tabla 13

Documentación para incluir en el sistema de checklist

Código	Denominación	Frecuencia / Uso
CHECK-SEC-01	Checklist mensual de cumplimiento de seguridad	Mensual (Soporte TI / SGSI)
FORM-INC-01	Formulario de reporte de incidente de seguridad	Cuando ocurra un incidente
FORM-ACC-01	Formulario de solicitud de acceso a sistemas	Cuando se requiera acceso
FORM-AUD-01	Formulario de auditoría de seguridad	Mensual / trimestral / por incidente

Nota: Tabla de elaboración propia

El sistema debe permitir:

- Completar cada checklist o formulario según los ítems y campos definidos en la documentación del SGSI.
- Registrar la fecha y el responsable de cada entrega.
- Almacenar las respuestas de forma segura y trazable.
- Consultar y filtrar entregas por tipo, período o responsable, según corresponda.

Funcionalidades que debe contemplar el sistema

A continuación se describen las funcionalidades que el sistema debería ofrecer para cumplir con el SGSI.

Aplicación de checklist (CHECK-SEC-01)

- Presentación de los 20 ítems de cumplimiento en formato Sí/No, con campos asociados de observación, acción correctiva y fecha de compromiso cuando la respuesta sea No.
- **Campos de contexto:** área evaluada, fecha de aplicación, responsable de aplicar (Soporte TI / SGSI), responsable de revisión, responsable SGSI.
- Cálculo automático de totales (Total Sí / Total No sobre 20).
- Campo de comentarios generales y espacio para indicar evidencia o ubicación de la misma (capturas, tickets, reportes).

Aplicación de formularios

- **FORM-INC-01:** Campos para datos del reportante, tipo de incidente, descripción, sistemas involucrados, evidencia, acción tomada, impacto y seguimiento por SGSI/DevOps.
- **FORM-ACC-01:** Datos del solicitante, accesos solicitados (correo, VPN, repositorio, CI/CD, etc.), nivel de acceso, justificación, duración (permanente/temporal) y flujo de aprobaciones (jefe inmediato, dueño del sistema, validación SGSI).
- **FORM-AUD-01:** Datos del auditor, área auditada, período, tipo de auditoría, alcance revisado, resultado del checklist asociado, hallazgos con severidad y acciones correctivas, resultado general (Cumple / Cumple parcialmente / No

Registro y trazabilidad

- Asignación de un identificador único (folio o ID) a cada entrega.
- Registro de fecha y hora de envío y, si aplica, de cierre o aprobación.

- Posibilidad de consultar entregas por tipo de documento, rango de fechas y responsable, para revisiones internas y auditoría.

Seguridad y control de acceso

- Acceso al sistema restringido a personal autorizado (según roles: usuarios finales, Soporte TI, SGSI, gerencia).
- Protección de la información almacenada (acceso solo a quienes deban aplicar, revisar o auditar).
- Respaldo periódico de los registros, alineado con la política de respaldo de la información del SGSI.

Usuarios y responsabilidades

Tabla 14

Usuarios del sistema para la aplicación de checklist y formularios

Rol / Área	Uso principal del sistema
Colaboradores	Completar y enviar FORM-INC-01 (reporte de incidentes) y FORM-ACC-01 (solicitud de acceso).
Soporte TI / DevOps	Aplicar CHECK-SEC-01, dar seguimiento a FORM-INC-01, ejecutar altas de acceso derivadas de FORM-ACC-01.
Responsable SGSI	Revisar checklist, validar solicitudes de acceso, registrar y dar seguimiento a auditorías (FORM-AUD-01).
Gerencia	Consultar resúmenes, aprobar políticas de uso del sistema y revisar resultados en revisiones de dirección.

Nota: Tabla de elaboración propia

Criterios de diseño recomendados

Para que el sistema sea útil y alineado al SGSI se recomienda:

- **Claridad:** Los formularios deben reflejar exactamente los ítems y campos definidos en los documentos CHECK-SEC-01, FORM-INC-01, FORM-ACC-01 y FORM-AUD-01.
- **Trazabilidad:** Cada envío debe quedar registrado con identificador, fecha y responsable.
- **Integración con procesos:** El uso del sistema debe estar integrado en los procedimientos de seguridad (gestión de incidentes, control de accesos, auditorías) y en las instrucciones para usuarios.
- **Revisión y mejora:** Periódicamente se debe evaluar si el sistema sigue siendo adecuado (cantidad de entregas, calidad de la información, tiempo de respuesta) y ajustar formularios o flujos si es necesario.

Opciones de implementación

La organización puede materializar este sistema mediante:

- Desarrollo propio y a la medida (intranet, aplicación web) si se requiere integración fuerte con IAM, flujos de aprobación o reportes específicos.
- Formularios en línea (por ejemplo, Google Forms, Microsoft Forms, Typeform) con hojas de cálculo o bases de datos asociadas para el almacenamiento y consulta.
- Módulos de cumplimiento o gestión de incidentes dentro de herramientas ya utilizadas (soporte, ITSM, ERP).
- Combinación de formularios en línea para captura y otra herramienta para almacenamiento, reportes y auditoría.

PLAN ESTRATÉGICO DEL SGSI

TecnoSystem S.A.

Sistema de Gestión de Seguridad de la Información – SGSI

1. CONTEXTO ORGANIZACIONAL

TecnoSystem S.A. es una empresa dedicada a la prestación de servicios tecnológicos, soporte informático y soluciones digitales empresariales, por lo que, debido a la naturaleza de sus operaciones, este gestiona información sensible relacionada con:

- Datos de clientes
- Información financiera
- Información contractual
- Credenciales de acceso a sistemas
- Información técnica y de infraestructura

Dada la creciente exposición a amenazas cibernéticas, riesgos internos y requisitos legales hace indispensable contar con una estrategia formal de seguridad de la información.

2. ALCANCE ESTRATÉGICO DEL SGSI

Se abarcará lo siguiente:

- Infraestructura tecnológica

- Sistemas de información internos
 - Plataformas en la nube
 - Procesos administrativos y operativos que manejen información
 - Personal interno y externo con acceso a información corporativa
-

3. MISIÓN DEL SGSI

Proteger la confidencialidad, integridad y disponibilidad de la información de TecnoSystem S.A., por medio de la implementación de controles de seguridad efectivos, gestión de riesgos y mejora continua.

4. VISIÓN DEL SGSI

TecnoSystem S.A. pretende consolidar como una organización confiable y resiliente en materia de seguridad de la información, fortaleciendo la confianza de clientes, aliados estratégicos y partes interesadas.

5. OBJETIVOS ESTRATÉGICOS DEL SGSI

5.1. Fortalecer la gestión de riesgos

- Identificar, analizar y tratar los riesgos de seguridad de la información.
- Mantener actualizado el inventario de activos críticos.

5.2.Implementar controles de seguridad

- Aplicar controles técnicos, físicos y administrativos.
- Establecer políticas formales de seguridad.

5.3.Promover la cultura de seguridad

- Capacitar al personal en buenas prácticas de seguridad.
- Implementar campañas de concientización periódicas.

5.4.Garantizar la continuidad operativa

- Desarrollar planes de respaldo y recuperación
- Implementar controles de continuidad del negocio ante incidentes.

5.5.Cumplimiento legal y contractual

- Asegurar el cumplimiento de normativas aplicables.
- Garantizar protección adecuada de datos de clientes.

6. ESTRATEGIAS CLAVE

Para conseguir los objetivos planteados, TecnoSystem S.A. aplicará las siguientes estrategias:

- Adopción de un enfoque basado en riesgos
 - Aplicación del ciclo PHVA por sus siglas Planificar, Hacer, Verificar, Actuar
 - Asignación del SGSI con la gestión general de la empresa.
 - Asignación de responsabilidades.
 - Evaluaciones periódicas de desempeño del sistema.
-

7. INDICADORES ESTRATÉGICOS – KPIS

Medir el avance del SGSI estableciendo los indicadores siguientes:

- Porcentaje de riesgos críticos tratados.
 - Número de incidentes de seguridad reportados.
 - Tiempo promedio de respuesta ante incidentes.
 - Porcentaje de colaboradores capacitados en seguridad.
 - Cumplimiento de auditorías internas.
-

8. RECURSOS ESTRATÉGICOS

Ejecutar el SGSI según los puntos a considerar:

- Recursos humanos-
 - Presupuesto para herramientas de seguridad.
 - Infraestructura tecnológica adecuada.
 - Servicios externos especializados cuando sea necesario.
-

9. HORIZONTE TEMPORAL

El plan estratégico tendrá un horizonte inicial de tres años, con revisiones anuales para evaluar su efectividad y realizar ajustes estratégicos.

10. COMPROMISO DE LA ALTA DIRECCIÓN

Se manifiesta su compromiso con la implementación y mejora continua del SGSI, proporcionando los recursos necesarios y dando a conocer una cultura organizacional orientada a la seguridad de la información.

Revisión y aprobación por parte de la alta dirección

Acta de revisión del sgsi por la alta dirección - TECNOSYSTEM S.A.

ACTA N°: 001-2026/SGSI

FECHA: 20 de marzo de 2026

HORA: 09:00 horas

LUGAR: Sala de Juntas, oficinas centrales TecnoSystem S.A., Zona 10, Guatemala

Asistentes

Mario Estuardo Chajon Arriza – Gerente General

Angelo Diancarlo Quezada Gallardo – Gerente de operaciones

Danny Josue Sosa Arroyo – Responsable SGSI / DevOps

Orden del día

1. Presentación del Sistema de Gestión de Seguridad de la Información (SGSI)
2. Análisis de la evaluación de riesgos y mapa de calor
3. Revisión de objetivos estratégicos de seguridad
4. Aprobación de políticas y procedimientos
5. Asignación de recursos y presupuesto
6. Compromisos y acuerdos

Desarrollo de la reunión

Presentación del SGSI

El responsable SGSI presentó el alcance completo del Sistema de Gestión de Seguridad de la Información para TecnoSystem S.A., detallando:

- La estructura documental del SGSI (políticas, procedimientos, manuales, formularios)
- La identificación de activos críticos de información
- El análisis de incidentes pasados que justifican la implementación
- La arquitectura de seguridad propuesta

Análisis de la evaluación de riesgos

Tabla 15

ID	Categoría de Riesgo	Nivel de Riesgo (PxI)	Prioridad
R-01	Ingeniería Social / Phishing	20 (CRÍTICO)	1
R-02	Seguridad en Desarrollo (Inyección SQL, librerías vulnerables)	20 (CRÍTICO)	1
R-04	Falta de Trazabilidad	16 (ALTO)	2
R-03	Amenazas Internas	15 (ALTO)	2
R-05	Pérdida de Información	15 (ALTO)	2

Se enfatizó que el riesgo R-01 (Ingeniería Social) presenta una probabilidad "Muy Alta" con un 71% de clics en pruebas internas, lo que representa la amenaza más inmediata para la organización.

Revisión de objetivos estratégicos

La dirección validó los objetivos de seguridad propuestos, confirmando su alineación con los objetivos generales de la empresa:

Tabla 16

Objetivo Empresarial	Contribución del SGSI	Estado
Brindar servicios tecnológicos confiables	Controles de seguridad en sistemas y plataformas	Validado
Proteger información empresarial y de clientes	Políticas de seguridad y gestión de riesgos	Validado
Garantizar continuidad del negocio	Planes de respaldo y recuperación	Validado
Fortalecer confianza de clientes	Prácticas alineadas con estándares internacionales	Validado

Aprobación de políticas y procedimientos

Tabla 17

Se sometieron a revisión y aprobación los siguientes documentos:

Documento	Versión	Código	Estado
Políticas de Seguridad de la Información	1	POL-SEG-2026-001	APROBADO
Manual de Procedimientos de Seguridad	1	MAN-PROC-001	APROBADO
Instrucciones de Seguridad para Usuarios	1	INS-SEC-01	APROBADO
Formulario de Reporte de Incidentes	1	FORM-INC-01	APROBADO
Formulario de Solicitud de Accesos	1	FORM-ACC-01	APROBADO
Checklist Mensual de Cumplimiento	1	CHECK-SEC-01	APROBADO
Formulario de Auditoría de Seguridad	1	FORM-AUD-01	APROBADO

Asignación de recursos y presupuesto

Tabla 18

La Gerencia General autorizó los siguientes recursos para el Trimestre 1 (marzo - junio 2026):

Concepto	Monto Asignado (Q)	Responsable
Herramienta de simulación de phishing (campañas)	Q8,000.00	DevOps
Licencias de herramientas SAST/SCA para análisis de código	Q15,000.00	DevOps
Plataforma de formación en ciberseguridad (e-learning)	Q5,000.00	Responsable SGSI
Horas hombre para implementación de controles	Según planificación	Gerencia de Operaciones

Acuerdos y compromisos

Aprobación formal del SGSI: La alta dirección aprueba en su totalidad el Sistema de Gestión de Seguridad de la Información presentado, así como todos sus documentos asociados.

Obligatoriedad de cumplimiento: Se instruye a la Gerencia de Operaciones y al responsable SGSI para comunicar oficialmente a todo el personal la entrada en vigencia de las políticas y procedimientos aprobados, siendo estos de cumplimiento obligatorio a partir del 1 de abril de 2026.

Programa de concientización: Se aprueba el plan de concientización detallado, con especial énfasis en la reducción del riesgo de phishing del 71% actual a menos del 10% en n año.

Recursos asignados: Se autoriza la ejecución del presupuesto asignado para el primer trimestre, debiendo presentarse un informe de avance en la próxima revisión.

Próxima revisión: Se agenda la siguiente revisión del SGSI por la alta dirección para el 19 de junio de 2026.

Confirmación de la alineación de los objetivos generales de la empresa

Asegurar la efectividad del Sistema de Gestión de Seguridad de la Información o bien SGSI, TecnoSystem S.A. ha llevado a cabo un análisis de correspondencia entre los objetivos estratégicos de la organización y los objetivos establecidos dentro del SGSI.

Lo cual permite garantizar que las actividades de seguridad de la información no se desarrollen de forma aislada, mas bien que contribuyan directamente al cumplimiento de la misión, visión y metas organizacionales de la empresa.

Objetivos generales de tecnosystem s.a.

- Brindar servicios tecnológicos confiables y de alta calidad a los clientes.
- Proteger la información empresarial y ala de los clientes.
- Mantener la continuidad de los servicios tecnológicos ofrecidos.
- Fortalecer la confianza de clientes y socios estratégicos.
- Optimizar los procesos internos mediante el uso seguro de tecnologías de la información.

Relación entre los objetivos empresariales y SGSI

El SGSI se desarrolla para apoyar directamente estos objetivos organizacionales mediante la aplicación de controles y prácticas de seguridad que garanticen la protección de los activos de información, por lo que, la relación entre ambos niveles puede observarse de la siguiente manera:

Tabla 19

Objetivo Empresarial	Contribución del SGSI
Brindar servicios tecnológicos confiables	Implementación de controles de seguridad que protejan los sistemas y plataformas en los servicios ofrecidos.
Proteger la información empresarial y de clientes	Aplicación de políticas de seguridad, controles de acceso y gestión de riesgos sobre los activos de información.
Garantizar la continuidad del negocio	Implementación de planes de respaldo, recuperación ante desastres y gestión de incidentes.
Fortalecer la confianza de clientes y aliados	Demostrar compromiso con la seguridad de la información mediante prácticas alineadas con estándares internacionales.
Optimizar procesos tecnológicos	Implementación de controles y procedimientos que permitan el uso seguro y eficiente de los sistemas de información.

Integración del SGSI en la estrategia organizacional

El SGSI se aplica dentro de la estrategia corporativa de TecnoSystem S.A. con el fin de ser componente fundamental para la gestión de riesgos tecnológicos y la protección de la información, ya que esto es reconocido por la alta dirección como un factor clave para:

- La sostenibilidad del negocio.
- La protección de los activos estratégicos.

- La competitividad en el mercado tecnológico.

Los objetivos SGSI son diseñados para apoyar directamente el crecimiento, estabilidad y confiabilidad de las operaciones de la empresa.

Establecimiento de mecanismos de revisión y actualización

Para garantizar la efectividad, vigencia y mejora continua del Sistema de Gestión de Seguridad de la Información/SGSI, TecnoSystem S.A. implementa mecanismos formales de revisión y actualización del plan estratégico y de los controles de seguridad implementados.

Los mecanismos permiten evaluar periódicamente el desempeño del SGSI, identificar oportunidades de mejora y adaptar las estrategias de seguridad a los cambios tecnológicos, organizacionales y del entorno.

Revisiones periódicas del SGSI

Se pretende evaluar el funcionamiento y verificar que los controles implementados continúan siendo adecuados para proteger los activos de información de la empresa, lo cual incluye las siguientes revisiones:

- Evaluación del cumplimiento de los objetivos de seguridad de la información.
- Análisis de incidentes de seguridad ocurridos.
- Revisión de la gestión de riesgos y de los controles implementados.
- Evaluación de la efectividad de las políticas y procedimientos de seguridad.

Las revisiones se realizarán al menos una vez al año o bien cuando se presente cambios significativos de la infraestructura tecnológica, en los procesos organizacionales o en el entorno de amenazas.

Auditorías internas

TecnoSystem S.A. llevará a cabo auditorías del SGSI con el objetivo de verificar el cumplimiento de las políticas, procedimientos y controles establecidos, esto permite que se cumpla los puntos siguientes:

- Detectar posibles debilidades en los controles de seguridad.
- Verificar el cumplimiento de las políticas de seguridad.
- Evaluar la correcta implementación de los procedimientos definidos.

Los resultados de las auditorías serán documentados y presentados a la alta dirección para la toma de decisiones y la implementación de acciones correctivas.

Revisión por la alta dirección

Se realizarán revisiones por la alta dirección de TecnoSystem S.A. las cuales serán periódicas, con el fin de evaluar el desempeño estratégico y asegurar que el sistema continúe alineado con los objetivos de la organización, los aspectos que se analizarán son:

- Resultados de auditorías internas.
- Indicadores de desempeño del SGSI.
- Incidentes de seguridad relevantes.
- Cambios en los riesgos organizacionales.
- Recomendaciones de mejora.

Esto permitirá tomar decisiones estratégicas para fortalecer el sistema de seguridad de la información

Actualización del plan estratégico del SGSI

Deberá de ser actualizado cuando se identifiquen los cambios que puedan afectar la seguridad de la información de la empresa, los cuales pueden ser:

- Cambios en la estructura organizacional.
- Implementación de nuevas tecnologías o sistemas.
- Aparición de nuevas amenazas o vulnerabilidades.
- Cambios en regulaciones o requisitos legales.

Lo cual requerirá de documentación formal y será comunicada a las áreas correspondientes para asegurar su correcta implementación.

Mejora continua

La empresa de TecnoSystem S.A. adoptará un enfoque de mejora continua, el cual se basa en el ciclo Planificar – Hacer – Verificar – Actuar o bien PHVA, con propósito de fortalecer constantemente el SGSI y adaptarlo a las necesidades cambiantes de la organización.

Esto permite que el SGSI evolucione junto con el crecimiento de la empresa, asegurando la protección permanente de la información y la continuidad de los servicios tecnológicos.

Plan de concientización diseñado y desarrollado por semanas/meses
PROGRAMA DE CONCIENTIZACIÓN EN SEGURIDAD DE LA INFORMACIÓN
- TECNOSYSTEM S.A.

CÓDIGO: PLAN-CONC-001

VERSIÓN: 1.0

FECHA: marzo 2026

RESPONSABLE: Responsable SGSI

PERÍODO: abril 2026 - marzo 2027

OBJETIVO: Reducir la tasa de clics en correos de phishing del 71% a menos del 10% en un año, y fortalecer la cultura de seguridad en toda la organización.

Estructura del programa

El programa está estructurado en 4 fases trimestrales, cada una con objetivos específicos, actividades semanales y materiales de apoyo.

TRIMESTRE 1: lanzamiento y sensibilización inicial (abril - junio 2026)

Objetivo del trimestre: Comunicar formalmente las nuevas políticas, sensibilizar sobre la importancia de la seguridad y establecer la línea base de conocimiento.

Tabla 20

Semana	Fechas	Actividad	Responsable	Material	Entregable / Evidencia
Semana 1	01-07/04/2026	Comunicación oficial de la Gerencia: Lanzamiento del SGSI y nuevas políticas	Gerencia General	Correo corporativo firmado por Gerencia	Correo enviado a todo el personal
Semana 2	08-14/04/2026	Inducción obligatoria: "Introducción al SGSI y Políticas de Seguridad"	Responsable SGSI	Presentación PPT (20 diapositivas), video introductorio (5 min)	Lista de asistencia firmada

Semana 3	15-21/04/2026	Módulo 1: "¿Qué es el phishing? Casos reales en TecnoSystem"	Responsable SGSI	Infografía, video testimonial simulado	Cuestionario de comprensión aplicado
Semana 4	22-28/04/2026	Primer simulacro de phishing (Línea base)	DevOps	Correo simulado: "Cupón de almuerzo - Semana del Empleado"	Reporte de resultados (tasa de clics)
Semana 5	29/04-05/05/2026	Revisión de resultados del simulacro y retroalimentación grupal	Responsable SGSI	Presentación con resultados agregados, infografía "Aprendamos juntos"	Acta de reunión por áreas
Semana 6	06-12/05/2026	Módulo 2: "Los 4 puntos para verificar antes de hacer clic"	Responsable SGSI	Poster digital, tarjeta de bolsillo (PDF), video corto (2 min)	Material distribuido a todo el personal
Semana 7	13-19/05/2026	Taller práctico: Análisis de correos reales vs. falsos	DevOps / SGSI	10 ejemplos de correos (reales y simulados) Correo simulado:	Ejercicio grupal completado
Semana 8	20-26/05/2026	Segundo simulacro de phishing	DevOps	"Actualización de firma electrónica" Tutorial paso a paso (PDF + video), checklist de verificación	Reporte de resultados comparativo % de activación de MFA verificado
Semana 9	27/05-02/06/2026	Módulo 3: "MFA: Tu segunda capa de defensa"	DevOps		Minuta de preguntas frecuentes
Semana 10	03-09/06/2026	Sesión de preguntas y respuestas abierta	Responsable SGSI	Foro virtual / reunión abierta	

Semana 11	10-16/06/2026	Tercer simulacro de phishing	DevOps	Correo simulado: "Notificación de seguridad - Cambio de contraseña"	Reporte de resultados trimestral
Semana 12	17-23/06/2026	Evaluación trimestral y reunión con Gerencia	Responsable SGSI	Informe ejecutivo trimestral	Acta de revisión con Gerencia
Semana 13	24-30/06/2026	Refuerzo: Comunicación de logros y áreas de mejora	Gerencia General	Correo de cierre de trimestre	Correo de cierre de trimestre

TRIMESTRE 2: fortalecimiento y técnicas avanzadas (julio - septiembre 2026)

Objetivo del trimestre: Profundizar en técnicas específicas de ataque y fortalecer la capacidad de identificación y reporte.

Tabla 21

Semana	Fechas	Actividad	Responsable	Material	Entregable / Evidencia
Semana 14	01-07/07/2026	Módulo 4: "Señales de alarma en correos electrónicos"	Responsable SGSI	Checklist avanzado (infografía), ejemplos comentados	Material distribuido
Semana 15	08-14/07/2026	Taller: Análisis de encabezados de correo y URLs sospechosas	DevOps	Guía práctica (PDF), herramienta de análisis	Ejercicio práctico
Semana 16	15-21/07/2026	Cuarto simulacro de phishing	DevOps	Correo simulado: "Invitación a webinar de ciberseguridad"	Reporte de resultados
Semana 17	22-28/07/2026	Módulo 5: "Smishing y Vishing: Ataques por	Responsable SGSI	Infografía, ejemplos de guiones de llamadas	Cuestionario aplicado

Semana 18	29/07-04/08/2026	SMS y llamadas" Simulación de llamada de Vishing (role play)	Responsable SGSI	Guión de llamada, grabación de ejemplo Correo simulado: "Problema con tu cuenta - Acción requerida"	Reporte de participación
Semana 19	05-11/08/2026	Quinto simulacro de phishing Módulo 6: "Ingeniería Social en redes sociales"	DevOps	Infografía, casos reales adaptados	Reporte de resultados
Semana 20	12-18/08/2026	Taller: Configuración de privacidad en redes sociales	Responsable SGSI	Guía práctica (PDF) Correo simulado: "Documento compartido contigo en Drive"	Material distribuido
Semana 21	19-25/08/2026	Sexto simulacro de phishing Módulo 7: "Cómo reportar incidentes: Uso del FORM-INC-01"	DevOps	Video tutorial, formulario de ejemplo	Checklist de configuración
Semana 22	26/08-01/09/2026	Evaluación trimestral y reunión con Gerencia	Responsable SGSI	Informe ejecutivo trimestral	Reporte de resultados
Semana 23	02-08/09/2026	Refuerzo: Casos de éxito y lecciones aprendidas	Responsable SGSI	Correo de cierre de trimestre	Tasa de uso del formulario
Semana 24	09-15/09/2026	Semana de refuerzo: Repaso general interactivo	Gerencia General	Juego de preguntas (Kahoot/trivia)	Acta de revisión con Gerencia
Semana 25	16-22/09/2026				Correo enviado
Semana 26	23-30/09/2026				Resultados del juego

TRIMESTRE 3: cultura de seguridad y especialización por roles (octubre - diciembre 2026)

Objetivo del trimestre: Adaptar los contenidos a roles específicos y consolidar hábitos de seguridad.

Tabla 22

Semana	Fechas	Actividad	Responsable	Material	Entregable / Evidencia
Semana 27	01-07/10/2026	Módulo 8: "Seguridad para desarrolladores: Código seguro" (Equipo Dev)	DevOps / Líder Desarrollo	Guía de buenas prácticas, checklist de revisión	Material específico para Dev
Semana 28	08-14/10/2026	Módulo 8a: "Seguridad para administrativos: Manejo de datos sensibles" (Equipo Adm)	Responsable SGSI	Guía específica, ejemplos prácticos	Material específico para Adm
Semana 29	15-21/10/2026	Séptimo simulacro de phishing (segmentado por roles)	DevOps	Correos dirigidos específicamente a cada área	Reporte de resultados por área
Semana 30	22-28/10/2026	Módulo 9: "Protección de información confidencial en trabajo híbrido"	Responsable SGSI	Infografía, checklist para teletrabajo	Material distribuido
Semana 31	29/10-04/11/2026	Taller: Cifrado y manejo seguro de dispositivos	DevOps	Tutorial de BitLocker, configuración de VPN	Configuración validada
Semana 32	05-11/11/2026	Correo simulado: "Actualización de política interna"	DevOps	Correo simulado: "Actualización de política interna"	Reporte de resultados
Semana 33	12-18/11/2026	Módulo 10: "Seguridad física y escritorio limpio"	Responsable SGSI	Poster, checklist de verificación física	Inspección de áreas
Semana 34	19-25/11/2026	Concurso: "Embajadores de"	Gerencia General	Comunicación de premiación	Embajadores designados

		Seguridad" - Elección de referentes por área			
Semana 35	26/11- 02/12/2026	Noveno simulacro de phishing Evaluación trimestral y reunión con Gerencia	DevOps	Correo simulado: "Encuesta de clima laboral"	Reporte de resultados
Semana 36	03- 09/12/2026	Cierre de año: Resultados y reconocimientos	Responsable SGSI	Informe ejecutivo trimestral	Acta de revisión con Gerencia
Semana 37	10- 16/12/2026		Gerencia General	Correo de cierre de año, reconocimientos	

TRIMESTRE 4: consolidación y mejora continua (enero - marzo 2027)

Objetivo del trimestre: Evaluar el impacto del programa, consolidar la cultura de seguridad y planificar el siguiente ciclo.

Tabla 23

Semana	Fechas	Actividad	Responsable	Material	Entregable / Evidencia
Semana 38	01- 07/01/2027	Módulo 11: "Revisión anual de políticas y actualizaciones"	Responsable SGSI	Documento resumen de cambios	Material distribuido
Semana 39	08- 14/01/2027	Taller de actualización para Embajadores de Seguridad	Responsable SGSI	Material exclusivo para embajadores Correo simulado:	Acta de reunión
Semana 40	15- 21/01/2027	Décimo simulacro de phishing	DevOps	"Oportunidad de capacitación externa"	Reporte de resultados
Semana 41	22- 28/01/2027	Módulo 12: "Nuevas amenazas: Tendencias en ciberseguridad"	Responsable SGSI	Infografía, noticias actualizadas	Material distribuido

		Simulacro integrado:			
		Ataque multifase			
Semana 42	29/01-04/02/2027	(correo + llamada)	DevOps / SGSI	Guión completo, coordinación	Reporte de ejercicio
		Análisis de resultados del simulacro integrado			
Semana 43	05-11/02/2027		Responsable SGSI	Informe detallado	Reunión de análisis
				Correo simulado:	
				"Revisión médica anual - Agenda tu cita"	
Semana 44	12-18/02/2027	Undécimo simulacro de phishing	DevOps		Reporte de resultados
		Encuesta de percepción de cultura de seguridad			
Semana 45	19-25/02/2027	Grupos focales	Responsable SGSI	Formulario de encuesta	Resultados de encuesta
		por área para retroalimentación			
Semana 46	26/02-04/03/2027	Duodécimo simulacro de phishing	Responsable SGSI	Guía de preguntas	Actas de reuniones
		(evaluación final)		Correo simulado:	
Semana 47	05-11/03/2027		DevOps	"Confirmación de asistencia a evento"	Reporte de resultados final
Semana 48	12-18/03/2027	Evaluación anual del programa	Responsable SGSI	Informe ejecutivo anual	Presentación a Gerencia
		Revisión estratégica y planificación			
Semana 49-50	19-31/03/2027	Año 2	Gerencia + SGSI	Plan de concientización Año 2	Plan aprobado

Listado de material de concientización que se desarrollará

Tabla 24

ID	Material	Tipo	Descripción	Formato	Trimestre	Responsable
MAT-INF-01	Los 4 puntos para verificar antes de hacer clic	Infografía	Infografía visual con los puntos clave: remitente, urgencia, enlace, adjuntos	PDF / JPG / Poster físico	T1	Diseñador Gráfico
MAT-INF-02	¿Qué es el phishing? Casos reales en TecnoSystem	Infografía	Explicación de phishing con ejemplos adaptados de incidentes pasados	PDF / JPG	T1	Responsable SGSI
MAT-INF-03	Aprendamos juntos: Resultados de simulacro	Infografía	Resultados agregados y aprendizajes del primer simulacro	PDF / JPG	T1	Responsable SGSI
MAT-INF-04	MFA: Tu segunda capa de defensa	Infografía	Explicación visual de MFA y cómo activarlo	PDF / JPG	T1	DevOps
MAT-INF-05	Señales de alarma en correos electrónicos	Infografía	Checklist avanzado con señales específicas	PDF / JPG	T2	Responsable SGSI
MAT-INF-06	Smishing y Vishing: Ataques por SMS y llamadas	Infografía	Explicación de ataques por mensajes de texto y llamadas	PDF / JPG	T2	Responsable SGSI
MAT-INF-07	Ingeniería Social en redes sociales	Infografía	Riesgos en RRSS y cómo proteger la información personal	PDF / JPG	T2	Responsable SGSI
MAT-INF-08	Protección de información en trabajo híbrido	Infografía	Buenas prácticas para	PDF / JPG	T3	Responsable SGSI

				trabajar desde casa/oficina		
MAT-09	Seguridad física y escritorio limpio	Infografía	Política de escritorio limpio y bloqueo de pantalla	PDF / JPG / Poster	T3	Responsable SGSI
MAT-10	Nuevas amenazas: Tendencias en ciberseguridad	Infografía	Actualización sobre amenazas emergentes	PDF / JPG	T4	Responsable SGSI
MAT-VID-01	Introducción al SGSI y Políticas de Seguridad	Video	Video introductorio (5 min) explicando el SGSI	MP4	T1	Responsable SGSI
MAT-VID-02	Testimonio simulado: Cómo caí en phishing	Video	Testimonio dramatizado de un empleado que cayó en phishing	MP4	T1	Responsable SGSI
MAT-VID-03	Video corto (2 min) Los 4 puntos para verificar	Video	Video corto (2 min) explicando los 4 puntos	MP4	T1	Responsable SGSI
MAT-VID-04	Cómo configurar MFA en 2 minutos	Video	Tutorial paso a paso para activar MFA	MP4	T1	DevOps
MAT-VID-05	Grabación de ejemplo de simulación de ataque Vishing	Video	Grabación de ejemplo de llamada fraudulenta	MP4	T2	Responsable SGSI
MAT-VID-06	Cómo usar FORM-INC-01	Video	Tutorial de uso del formulario de incidentes	MP4	T2	Responsable SGSI
MAT-VID-07	Tutorial de configuración de BitLocker y VPN	Video	Tutorial de cifrado y conexión segura	MP4	T3	DevOps

MAT - ELE-01	Curso: "Introducción al Phishing"	E-learning	Módulo interactivo con preguntas al final	SCORM / Plataforma	T1	Responsable SGSI
MAT - ELE-02	Curso: "Buenas prácticas de contraseñas"	E-learning	Módulo interactivo sobre gestión de contraseñas	SCORM / Plataforma	T1	Responsable SGSI
MAT - ELE-03	Curso: "Seguridad para desarrolladores"	E-learning	Módulo específico para equipo de desarrollo	SCORM / Plataforma	T3	DevOps
MAT - ELE-04	Curso: "Seguridad para administrativos"	E-learning	Módulo específico para equipo administrativo	SCORM / Plataforma	T3	Responsable SGSI
MAT - GUI-01	Guía de análisis de encabezados de correo	Guía práctica	PDF con pasos para analizar encabezados	PDF	T2	DevOps
MAT - GUI-02	Checklist de configuración de privacidad en RRSS	Guía práctica	Checklist paso a paso	PDF	T2	DevOps
MAT - GUI-03	Guía de buenas prácticas para código seguro	Guía práctica	Documento técnico para desarrolladores	PDF	T3	DevOps / Líder Desarrollo
MAT - GUI-04	Checklist de teletrabajo seguro	Guía práctica	Lista de verificación para trabajo remoto	PDF	T3	Responsable SGSI
MAT -PPT-01	Presentación lanzamiento SGSI	PPT	Presentación para inducción inicial	PPTX	T1	Responsable SGSI
MAT -PPT-02	Presentación resultados trimestrales	PPT	Plantilla para informes trimestrales	PPTX	T1-T4	Responsable SGSI
MAT -PPT-03	Presentación para Embajadores de Seguridad	PPT	Material exclusivo para capacitación	PPTX	T4	Responsable SGSI

de
embajadores

MAT						
-	Correo		Correo oficial			
COM	lanzamiento	Comunicaci	de	HTML /		Gerencia
-01	Gerencia	ón	lanzamiento	Texto	T1	General
MAT						
-	Boletín		Plantilla de			
COM	mensual de	Comunicaci	boletín	HTML /		Responsabl
-02	seguridad	ón	mensual	Texto	T1-T4	e SGSI
MAT						
-	Correo de		Plantilla de			
COM	cierre de	Comunicaci	comunicación	HTML /		Gerencia
-03	trimestre	ón	de resultados	Texto	T1-T4	General
	Juego					
MAT	"Memory" de		Juego de	HTML /		
-INT-	señales de		memoria	Plataform		Responsabl
01	phishing	Interactivo	digital	a	T2	e SGSI
MAT	Trivia de		Preguntas de			
-INT-	seguridad		repaso en			Responsabl
02	(Kahoot)	Interactivo	formato juego	Kahoot	T2/T4	e SGSI
			12 guiones de			
MAT	Guiones para		correos para			
-INT-	simulacros de	Material	simulacros	TXT /		
03	phishing	simulacro	mensuales	HTML	T1-T4	DevOps

Plan de evaluación periódica de la efectividad del programa

INDICADORES CLAVE DE DESEMPEÑO (KPIs)

KPI 1: Tasa de clics en simulacros de phishing

Concepto	Descripción
Objetivo	Medir el porcentaje de colaboradores que hacen clic en enlaces de correos simulados de phishing
Fórmula	(Número de clics / Número de correos entregados) x 100
Frecuencia	Mensual (posterior a cada simulacro)
Línea base	71% (medición inicial - prueba interna 2024)
Meta 12 meses	< 10%
Hitos intermedios	T1: < 50% T2: < 30% T3: < 15% T4: < 10%
Responsable medición	DevOps
Destinatarios	Responsable SGSI, Gerencia de Operaciones, Gerencia General

KPI 2: Tasa de reporte de phishing

Concepto	Descripción
Objetivo	Medir el porcentaje de usuarios que, ante un correo de phishing (real o simulado), lo reportan utilizando el canal definido (botón de reporte o FORM-INC-01)
Fórmula	$\left(\frac{\text{Número de reportes recibidos}}{\text{Número de correos simulados entregados}} \right) \times 100$
Frecuencia	Mensual (posterior a cada simulacro)
Línea base	5% (estimado inicial)
Meta 12 meses	> 50%
Hitos intermedios	T1: > 15% T2: > 25% T3: > 35% T4: > 50%
Responsable medición	Responsable SGSI
Destinatarios	Responsable SGSI, Gerencia de Operaciones

KPI 3: Cobertura de capacitación

Concepto	Descripción
Objetivo	Medir el porcentaje de colaboradores que completan los cursos obligatorios de seguridad
Fórmula	$\left(\frac{\text{Número de colaboradores que completaron}}{\text{Total de colaboradores activos}} \right) \times 100$
Frecuencia	Trimestral
Línea base	0% (programa nuevo)
Meta	100% de cumplimiento en cada curso obligatorio
Responsable medición	Responsable SGSI
Destinatarios	Responsable SGSI, Gerencia General

KPI 4: Evaluación de conocimiento

Concepto	Descripción
Objetivo	Medir el nivel de comprensión de los contenidos a través de evaluaciones posteriores a los módulos de formación
Fórmula	Promedio de calificaciones en cuestionarios
Frecuencia	Por cada módulo de formación (mínimo trimestral)
Línea base	No aplica
Meta	Promedio de calificación > 85%
Responsable medición	Responsable SGSI
Destinatarios	Responsable SGSI

KPI 5: Tiempo de respuesta ante incidentes reportados

Concepto	Descripción
Objetivo	Medir la eficiencia en la atención de incidentes reportados por usuarios
Fórmula	Tiempo promedio desde el reporte hasta la contención inicial
Frecuencia	Mensual
Línea base	48 horas (estimado)
Meta	< 4 horas para incidentes críticos
Responsable medición	DevOps
Destinatarios	Responsable SGSI, Gerencia de Operaciones

KPI 6: Encuesta de percepción de cultura de seguridad

Concepto	Descripción
Objetivo	Evaluar la percepción de los colaboradores sobre la importancia de la seguridad y su confianza para identificar amenazas
Fórmula	Puntuación promedio en escala 1-10 en encuesta anónima
Frecuencia	Semestral (T2 y T4)
Línea base	5/10 (estimado inicial)
Meta	> 8/10
Responsable medición	Responsable SGSI
Destinatarios	Responsable SGSI, Gerencia General

KPI 7: Reincidencia por usuario

Concepto	Descripción
Objetivo	Identificar usuarios que caen en múltiples simulacros para aplicar refuerzo específico
Fórmula	Número de usuarios que han hecho clic en 2 o más simulacros consecutivos
Frecuencia	Trimestral
Línea base	No aplica
Meta	0 usuarios con 3 o más clics en el año
Responsable medición	Responsable SGSI
Destinatarios	Responsable SGSI (para acciones focalizadas)

Cronograma de evaluaciones

Evaluación	Fecha	Responsable	Entregable
Evaluación T1	30/06/2026	Responsable SGSI	Informe Ejecutivo T1
Revisión con Gerencia T1	3/07/2026	Responsable SGSI	Acta de Revisión
Evaluación T2	30/09/2026	Responsable SGSI	Informe Ejecutivo T2
Revisión con Gerencia T2	3/10/2026	Responsable SGSI	Acta de Revisión
Evaluación T3	31/12/2026	Responsable SGSI	Informe Ejecutivo T3
Revisión con Gerencia T3	4/01/2027	Responsable SGSI	Acta de Revisión
Evaluación Anual T4	31/03/2027	Responsable SGSI	Informe Ejecutivo Anual
Revisión Estratégica Anual	3/04/2027	Gerencia + SGSI	Plan Año 2 Aprobado

Este plan de evaluación garantiza que el programa de concientización no sea solo una actividad administrativa, sino un proceso medible, ajustable y alineado con el objetivo estratégico de reducir el riesgo de ingeniería social del 71% a menos del 10% en un año, contribuyendo directamente a la protección de los activos de información de TecnoSystem S.A.

CONCLUSIONES

1. Diagnóstico situacional fundamentado: El análisis de los ocho incidentes de seguridad documentados permitió identificar con precisión las vulnerabilidades reales de TecnoSystem S.A., estableciendo una línea base objetiva para el diseño del SGSI. La tasa de clics en phishing del 71% y los 17 incidentes de manipulación de red en un semestre evidencian la urgencia de implementar controles formales.
2. Gestión de riesgos integral: La matriz de riesgos desarrollada clasificó correctamente las amenazas, identificando dos riesgos críticos (R-01 Ingeniería Social y R-02 Seguridad en Desarrollo) con puntuación 20/25, lo que permitió priorizar recursos y acciones de manera efectiva. El mapa de calor y el plan de tratamiento por prioridad (crítica, alta y media) proporcionan una hoja de ruta clara para la organización.
3. Marco normativo y documental completo: Se estableció un conjunto de políticas, procedimientos, instructivos y formularios que cubren todos los dominios de seguridad relevantes: control de acceso, gestión de contraseñas, clasificación de información, respaldo, desarrollo seguro, seguridad física, gestión de incidentes, y uso de inteligencia artificial, entre otros. La documentación generada es práctica, aplicable y está lista para su implementación inmediata.
4. Alineamiento estratégico demostrado: Se confirmó la correspondencia entre los objetivos del SGSI y los objetivos generales de la empresa, validando que las actividades de seguridad no son un fin aislado, sino que contribuyen directamente a la misión de brindar servicios tecnológicos confiables, proteger la información de clientes, garantizar la continuidad del negocio y fortalecer la confianza de los stakeholders.
5. Compromiso de la alta dirección asegurado: El acta de revisión y aprobación del SGSI por parte de la Gerencia General (ACTA N° 001-2026/SGSI) formaliza el respaldo institucional, asigna recursos específicos para el primer trimestre (Q28,000.00 en herramientas) y establece la obligatoriedad de las políticas a partir del 1 de abril de 2026, garantizando la gobernanza del sistema.
6. Programa de concientización estructurado: Se diseñó un plan anual de concientización por semanas, con 49 semanas de actividades, 12 simulacros de phishing, materiales específicos por rol (desarrolladores, administrativos) y un sistema de evaluación basado

en 7 KPIs, demostrando un enfoque metodológico para abordar el riesgo crítico de ingeniería social.

7. Mecanismos de mejora continua establecidos: Se definieron revisiones periódicas del SGSI, auditorías internas, revisiones por la alta dirección trimestrales y un proceso formal de actualización ante cambios organizacionales o del entorno, asegurando que el sistema evolucione y se mantenga efectivo en el tiempo.
8. Aplicabilidad práctica del proyecto: El SGSI desarrollado no es un ejercicio teórico, sino un conjunto de herramientas listas para ser implementadas: políticas formalizadas, procedimientos operativos, formularios de uso diario (reporte de incidentes, solicitud de accesos, checklists de cumplimiento) y diagramas de arquitectura que facilitan la comprensión y ejecución por parte de todo el personal.

RECOMENDACIONES

1. Ejecutar el plan de implementación priorizado: Iniciar inmediatamente con las acciones de prioridad crítica (0-3 meses) establecidas en el plan de tratamiento: implementación del programa de concientización y simulacros de phishing mensuales (R-01), y adquisición de herramientas SAST/SCA para análisis de seguridad en el desarrollo (R-02), utilizando el presupuesto aprobado de Q28,000.00 para el primer trimestre.
2. Comunicar formalmente las políticas: Realizar una comunicación oficial firmada por Gerencia General anunciando la entrada en vigencia de las políticas de seguridad a partir del 1 de abril de 2026, enfatizando su carácter obligatorio y las consecuencias del incumplimiento. Incluir en esta comunicación el respaldo de la alta dirección al SGSI.
3. Asignar responsables claros: Designar formalmente al Responsable SGSI (Danny Josue Sosa Arroyo) con autoridad suficiente para supervisar el cumplimiento de las políticas, coordinar el programa de concientización, gestionar los incidentes de seguridad y reportar directamente a Gerencia en las revisiones trimestrales.
4. Ejecutar el programa de concientización según lo planificado: Seguir el cronograma semanal establecido para el Trimestre 1 (abril-junio 2026), asegurando la realización del primer simulacro de phishing en la Semana 4 y documentando los resultados como línea base para medir la mejora.
5. Implementar los formularios y checklists: Poner en producción los formularios FORM-INC-01 (reporte de incidentes), FORM-ACC-01 (solicitud de accesos) y el checklist mensual CHECK-SEC-01, asegurando que todo el personal conozca su existencia, ubicación y forma correcta de uso.
6. Activar controles técnicos prioritarios: Configurar la autenticación multifactor (MFA) para todo el personal en correo, VPN y repositorios; implementar el bloqueo de puertos USB no autorizados mediante GPO; y activar el cifrado de discos (BitLocker) en todos los equipos corporativos.
7. Realizar la primera revisión trimestral: Programar para el 19 de junio de 2026 la reunión de revisión del SGSI con la alta dirección, donde se presentarán los resultados del Trimestre 1 (incluyendo los tres primeros simulacros de phishing), el avance en la implementación de controles y el informe de ejecución presupuestaria.

8. Documentar lecciones aprendidas: Establecer un registro de incidentes de seguridad y lecciones aprendidas, alimentado por los reportes FORM-INC-01, que permita ajustar continuamente los controles y el programa de concientización.

REFERENCIAS BIBLIOGRÁFICAS

Normas Técnicas Internacionales

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems - Requirements. <https://www.iso.org/standard/27001.html>

International Organization for Standardization. (2022). *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection - Information security controls. <https://www.iso.org/standard/75652.html>

Libros y Textos Académicos

Calder, A. (2020). *ISO 27001/ISO 27002: A guide to information security management systems*. IT Governance Publishing.

Humphreys, E. (2016). *Implementing the ISO/IEC 27001:2013 ISMS*. Artech House.

Stallings, W., & Brown, L. (2018). *Computer security: Principles and practice* (4th ed.). Pearson.

Whitman, M. E., & Mattord, H. J. (2021). *Principles of information security* (7th ed.). Cengage Learning.

Publicaciones de Organismos Gubernamentales y Especializados

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53 Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2018). *Computer security incident handling guide* (NIST Special Publication 800-61 Rev. 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-61r2>

Artículos y Publicaciones Periódicas

Jagatic, T. N., Johnson, N. A., Jakobsson, M., & Menczer, F. (2007). Social phishing. *Communications of the ACM*, 50(10), 94–100. <https://doi.org/10.1145/1290958.1290968>

Hong, J. (2012). The state of phishing attacks. *Communications of the ACM*, 55(1), 74–81. <https://doi.org/10.1145/2063176.2063197>

Documentos Internos de TecnoSystem S.A.

TecnoSystem S.A. (2026). *DOC-01 Perfil de la empresa* [Documento interno].

TecnoSystem S.A. (2026). *DOC-03 Inventario de activos críticos* [Documento interno].

TecnoSystem S.A. (2026). *DOC-05 Matriz de roles y accesos* [Documento interno].

TecnoSystem S.A. (2026). *DOC-07 Respaldo y recuperación* [Documento interno].